

Santiago García Santiago

2022-2023

Apuntes empleados durante el transcurso del segundo año del ciclo formativo. Originariamente no fueron redactados al uso de "manual" por ello presentan irregularidades de maquetación. Aun así, el indexado de contenidos se llevó a cabo al fin de facilitar su consulta a posterior.

22-08-23

Unidad_01:

- [\[05\] La importancia de la SI](#)
- [\[05\] Objetivo fundamental](#)
- [\[06\] Objetivos de la seguridad de la información](#)
- [\[08\] Tipos de amenazas](#)
- [\[08\] Tipos de seguridad informática](#)
- [\[08\] Protección física de los equipos](#)
- [\[09\] Protección activa vs pasiva](#)
- [\[10\] Concepto CPD](#)

Unidad_02:

- [\[11\] Tipos de ataque - Amenazas lógicas](#)
 - [\[13\] Tipos de ataque según su proceder](#)
 - [\[15\] Técnicas de ataque](#)
 - [\[16\] Terminología hacker](#)
 - [\[17\] Motivaciones de los hacker](#)
 - [\[18\] Exploits](#)
 - [\[18\] Herramientas empleadas durante un ataque](#)
 - [\[19\] Hacking ético](#)
 - [\[19\] Buenas practicas](#)
 - [\[20\] Anexo pentesting: Herramientas básicas auditoria seguridad SI](#)
 - [\[20\] Anexo pentesting Rastreo de exploits - NMAP](#)
 - [\[27\] Anexo pentesting Hydra - Medusa](#)
 - [\[29\] Anexo pentesting Google dorks](#)
-

UD2 – Legislación y normativa :

- [\[31\] Legislación y normativa](#)
- [\[31\] Niveles de seguridad LOPD 2018](#)
- [\[35\] RGPD](#)
- [\[35\] Características del RGPD](#)
- [\[36\] Principios clave del RGPD](#)
- [\[37\] Implicaciones del RGPD](#)
- [\[38\] Seguridad de los datos](#)
- [\[39\] LSSICE](#)
- [\[39\] LSSICE – eCommerce](#)
- [\[40\] LSSICE – Intermediarios](#)
- [\[40\] LSSICE – Páginas web](#)
- [\[40\] LSSICE – Garantías y derechos de los usuarios](#)
- [\[41\] ISO 27000](#)
- [\[41\] LPI | Ley de propiedad Intelectual](#)
- [\[41\] Regulación de los derechos de autor en internet](#)
- [\[43\] Código penal](#)
- [\[44\] Anexo Legislación 01](#)
- [\[45\] Anexo Legislación 02 \(RGPD\)](#)

Unidad_03:

- [\[52\] Criptografía](#)
- [\[52\] Algoritmos de cifrado](#)
- [\[52\] Criptografía simétrica \(Clave privada\)](#)
- [\[54\] Criptografía asimétrica \(Clave pública\)](#)
- [\[55\] Tarjeta inteligente \(Smart-card\)](#)
- [\[56\] Sistema híbrido](#)
- [\[56\] Función Hash](#)
- [\[57\] Firma digital y Certificados electrónicos](#)
- [\[58\] Certificado electrónico o digital](#)
- [\[59\] PKI \(Public Key Infrastructure\)](#)

Unidad_03:

[02]

[\[60\] Root certificate](#)[\[60\] Protocolos de comunicación](#)[\[61\] Protocolo SSH](#)

Unidad_04:

[\[62\] Seguridad pasiva - SAI](#)[\[63\] Copias de seguridad - Backup](#)[\[63\] Copias de seguridad - Regla 3-2-1](#)[\[64\] Copias de seguridad - Dispositivos de Backup](#)[\[64\] Copias de seguridad - Tipos de Backup](#)[\[65\] Imagen del sistema](#)[\[65\] Modelos de almacenamiento](#)[\[67\] Balanceador de carga](#)[\[68\] DRP \(Disaster Recovery Plan\)](#)

Unidad_05:

[\[68\] Seguridad activa](#)[\[68\] Seguridad activa en el sistema](#)[\[69\] Seguridad activa en la BIOS y gestores de arranque](#)[\[69\] Tipos de BIOS](#)[\[69\] Reset de BIOS](#)[\[69\] Boot manager \(GRUB\)\]](#)[\[70\] Cifrado de particiones](#)[\[70\] Seguridad lógica](#)[\[70\] Política de contraseñas](#)[\[70\] Reglas de creación de contraseñas](#)[\[71\] Trucos creación de contraseñas](#)[\[71\] Monitorización del sistema](#)

Unidad_06:

- [\[72\] Redes cableadas](#)
- [\[72\] Arquitecturas de red](#)
- [\[72\] Protección ante vulnerabilidades](#)
- [\[72\] VLAN \(Virtual LAN\)](#)
- [\[73\] Medidas de seguridad VLAN](#)
- [\[73\] Servidor RADIUS](#)
- [\[73\] WLAN \(Wireless LAN\)](#)
- [\[73\] Protección ante vulnerabilidades WLAN](#)
- [\[74\] Tipos de autenticación WLAN](#)
- [\[74\] Cifrado WEB, WPA,WPA2](#)
- [\[74\] VPN \(Virtual Private Network\)](#)
- [\[74\] Protocolos VPN](#)

Unidad_07:

- [\[75\] Herramientas de control de redes](#)
- [\[76\] Tipos de IDS / IPS](#)
- [\[76\] Firewall](#)
- [\[76\] Firewall personal](#)
- [\[76\] Firewall domestico SOHO](#)
- [\[76\] Firewall de nivel de aplicación](#)
- [\[77\] Firewall de red](#)
- [\[77\] Concepto de IPtables/Netfilter](#)
- [\[77\] ufw \(Uncomplicated Firewall\)](#)
- [\[77\] Servidor proxy \(Proxy server\)](#)
- [\[77\] Proxy web \(Proxy inverso\)](#)
- [\[77\] Ettercap](#)
- [\[78\] Protocolo IPsec](#)
- [\[78\] Kerberos](#)
- [\[79\] DMZ](#)

1-La importancia de la SI

La informática está presente en todos los ámbitos: Casa, empresas, móviles, super ordenadores...

Todos manejan información confidencial y valiosa.

La información tiene que ser accesible en todo momento.

Und
01

Por esto son necesarias la seguridad informática y la alta disponibilidad

2-Que es la seguridad informática

La seguridad informática es la disciplina que involucra técnicas, aplicaciones y dispositivos que aseguran la autenticidad, integridad y privacidad de la información contenida dentro de un sistema informático, así como su transmisión.

3-¿Es posible la seguridad total?

No, pero si tomar las máximas medidas de seguridad (al alcance y en presupuesto).

4-Importancia de la seguridad informática

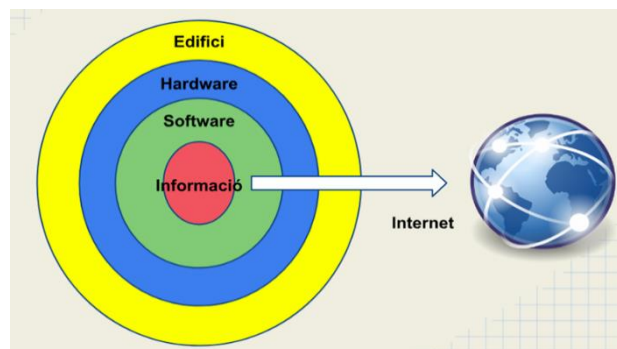
- Detectar los problemas y amenazas de seguridad (minimizar y gestionar los riesgos)
- Garantizar la adecuada utilización de recursos y aplicaciones.
- Limitar pérdidas y conseguir la recuperación del sistema en caso de incidente de seguridad.
- Cumplir con el marco legal y los requisitos a nivel organizativo.

5-Objetivo fundamental:

“La información (datos) es el activo primordial a proteger y el más difícil de recuperar”

6-¿Qué proteger?

- Datos
- Aplicaciones
- Equipos
- Comunicaciones



7- ¿Qué proteger?**[Equipos]**

- Robos
- Intentos de conexión equipos no autorizados.
- Desconexión del servidor.
- Prevenir averías (humedad, calor...)
- Mal diseño o errores de fabricación.
- Problemas de energía (subidas de tensión...)

8- ¿Qué proteger?**[Software]**

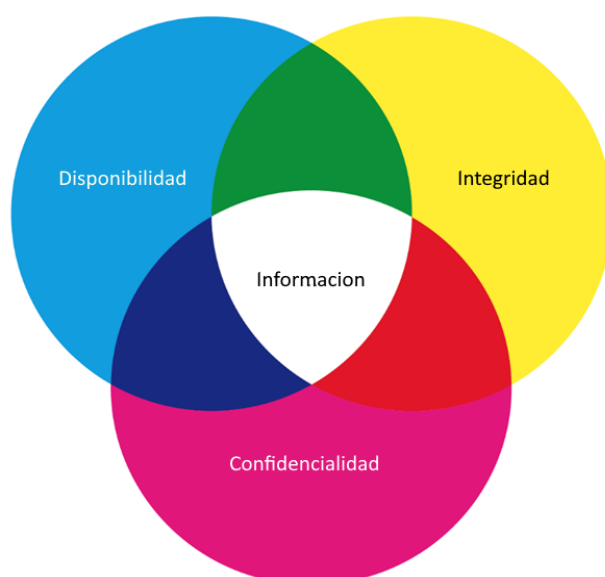
- Barreras antivirus.
- Limitar los privilegios.
- Maquetar sistema: Evitar que los usuarios puedan instalar cosas.
- Descargar de fuentes o repositorios fiables, o paginas oficiales.
- Actualizar las aplicaciones.
- Control de actualizaciones.

9- ¿Qué proteger?**[Datos]**

- Proteger ante software malicioso que robe o altere datos.
- Copias de seguridad.
- Almacenamiento cifrado.

10- ¿Qué proteger?**[Comunicaciones]**

- Canales de comunicación cifrados.
- Control de las conexiones en la red.
- Evitar spam y publicidad.
- Cloud computing.
- Proteger almacenamiento en la red.
- Protocolos / aplicaciones seguras: SSH, VPN, TLS /SSL

11-Objetivos de la seguridad de la información:**-Disponibilidad.****-Integridad.****-Confidencialidad.**

12-Fiabilidad

“ El único sistema que es totalmente seguro es aquel que se encuentra apagado y desconectado, guardado en una caja fuerte de titanio y enterrado en cemento, rodeado de gas nervioso y de un grupo de guardias fuertemente armados. Aun así no me apostaría la vida”

-Eugenne H.Spalford



Un sistema totalmente seguro es imposible. Así que el objetivo es que sea fiable.

13- Objetivos de la seguridad de la información:

Confidencialidad	Calidad de un mensaje, comunicación o datos que solo puede ser entendido por la persona a la que le es enviado.
Integridad	Calidad de un mensaje, comunicación o datos que permite comprobar que no ha sido alterado.
Disponibilidad	Capacidad de un servicio, sistema o datos para ser accesibles y utilizables por usuarios o procesos cuando se les requiera.

Autenticidad	Verificar que un mensaje pertenece a un usuario concreto (usuario, login, contraseña)
Fiabilidad	Verificar que el contenido del mensaje no ha sido alterado.
No repudio	Permite probar la participación de las partes en una comunicación.
Auditabilidad	Auditorias de seguridad.

15-Recomendaciones

- Actualizar sistemas.
- Configurar la actualización automática de aplicaciones.
- Activar la notificación de actualizaciones automáticas.
- Comprobar la fiabilidad antes de instalar las aplicaciones.
- Configurar herramientas de seguridad; antivirus, cortafuegos, Backus.

15- Tipos de amenazas**16-Tipos de seguridad informática****17 - Protección física de los equipos****Entorno físico**

Humedad, luz solar, temperaturas, polvo, campos magnéticos, vibraciones, golpes...

Instalaciones

Eléctrica, de red, protección ante incendios...

Control de accesos

Vigilancia, códigos de seguridad, acceso con dispositivos...

18 - Protección física de los equipos**[02]**

- Mantener los **servidores** y todos los elementos centrales del sistema en una zona de acceso físico restringido.
- Mantener los **dispositivos de almacenamiento** en un lugar diferente al resto de la maquinaria.
- Llevar a cabo **inventarios o registros** de todos los elementos del sistema informático (útil en casos de robo).
- Proteger u aislar el **cableado de red** (tanto para protegerlo de daños físicos como de espionaje).
- Instalar **cámaras de video vigilancia** (hace falta tener presente la normativa que regula la instalación).
- Escoger una **topología de red** adecuada a las nuestras necesidades.
- Garantizar la **seguridad del hardware de red** (routers, conectores, switches y módems).
- Proveer **mecanismos de autenticación** a los usuarios que quieran acceder al sistema.

19 – Protección activa vs pasiva**Corta fuegos (Firewall)**

Elemento de hardware o software que se utiliza en redes de equipos informáticos para controlar las comunicaciones.

SAI

Dispositivo que almacena energía gracias a unas baterías integradas y que da soporte en caso de fallo eléctrico > en ingles UPS (Uninterruptible Power Supply) > SAI offline/Standby / SAI online

20 – Seguridad activa**[Objetivos]**

- Diseñar sistemas y redes con un alto grado de seguridad.
- **Investigar, documentar y prevenir** incidentes de seguridad.
- Diseñar **políticas de seguridad**.
- Monitorizar los sistemas y redes para identificar incidentes y vulnerabilidades.
- **Analizar** la seguridad de los sistemas, redes y aplicaciones.

21 – Seguridad pasiva**[Objetivos]**

La seguridad pasiva **intenta minimizar el impacto y las consecuencias** causadas por el accidente. Son medidas o acciones **posteriores** a un ataque o incidente.

Posibles consecuencias:

- Pérdida o mal funcionamiento del hardware.
- Falta de disponibilidad de servicios.
- Pérdida de información.

22- Concepto de CPD

Se denomina centro de procesamiento de datos al espacio donde se concentran los recursos necesarios para el procesamiento de la información de una organización.

23- Concepto de copias de seguridad (backup)

El procedimiento más inútil mientras todo va bien, y el que más se echa en falta cuando hay problemas.

Local

En el mismo equipo, disco, o disco externo.

Remota

En otro punto de la red, servidor o cloud computing.

01-Tipos de ataque**[Amenazas lógicas]****Und****02**

Virus	Spyware	Gusano
Adware	Troyano	Ransomware
Backdoor	Rootkit	Rogueware
Pharming	Ddos/Dos	Botnet

Definiciones:**[Opcional]****Virus**

Un virus informático es un software malicioso que tiene por objetivo alterar el funcionamiento del ordenador que infecta, corrompiendo la información, destruyéndola o secuestrándola.

Spyware

Es un software malicioso que infecta un sistema para después monitorizarlo, robando información de modo silencioso, transmitiendo está a terceros sin el conocimiento del propietario del equipo.

Gusano

Un gusano informático es un malware que se replica para propagarse sin fin a otros equipos. El principal objetivo de los gusanos informáticos es propagarse y afectar al mayor número de dispositivos posible. Para ello crean copias de si mismos en el ordenador infectado que distribuyen posteriormente a través de diferentes medios, como el correo electrónico, o programas P2P entre otros.

Adware

Es un software malicioso que se muestra como publicidad, su fin es recopilar todo tipo de información del usuario para posteriormente mostrarle publicidad de modo abusivo. Los datos que recopila son de todo tipo, sin censura ni respeto por la privacidad.

01-Tipos de ataque**[Amenazas lógicas] [02]****Definiciones:****[Opcional]****Troyano**

Es un tipo de malware que se oculta en el interior de ejecutables de aplicaciones aparentemente inofensivas. Al instalarse puede provocar todo tipo de daños; desde el secuestro del sistema, creación de backdoors, instalación de Rootkits o incluso spywares.

Ransomware

Un ransomware o 'secuestro de datos' en español, es un tipo de programa dañino que restringe el acceso a determinadas partes o archivos del sistema operativo infectado y pide un rescate a cambio de quitar esta restricción.

Backdoor

Backdoor, como su nombre indica, es una puerta trasera de acceso a los equipos o servidores, de manera que los crackers que las utilizan, podrán enviar y recibir archivos, borrar o robar datos, reiniciar el ordenador, instalar nuevos programas. Es importante destacar que las Backdoor en la mayoría de las ocasiones no son detectadas ni por el firewall ni el antivirus.

Rootkit

Un rootkit es un paquete de software malicioso diseñado para permitir el acceso no autorizado a un equipo o a otro software. Los rootkits son difíciles de detectar y pueden ocultar su presencia en un sistema infectado.

Rogueware

O "falso antivirus" Un rogueware (término surgido de la unión de las palabras inglesas rogue y malware) es una forma de software malicioso que engaña a los usuarios haciéndoles creer que hay un virus en el ordenador, cuando en realidad es el software malicioso.

Pharming

El pharming, una combinación de los términos "phishing" y "farming", es un tipo de cibercrimen muy semejante al phishing, en el que el tráfico de un sitio web es manipulado para permitir el robo de información confidencial.

01-Tipos de ataque**[Amenazas lógicas] [03]****Definiciones:****[Opcional]****Phishing**

El phishing se refiere al envío de correos electrónicos que tienen la apariencia de proceder de fuentes de confianza (como bancos, compañías de energía etc.) pero que en realidad son imitaciones de las paginas reales. Gracias a esto los crackers recopilan la información confidencial sobre el acceso a esos servicios.

Ddos/Dos

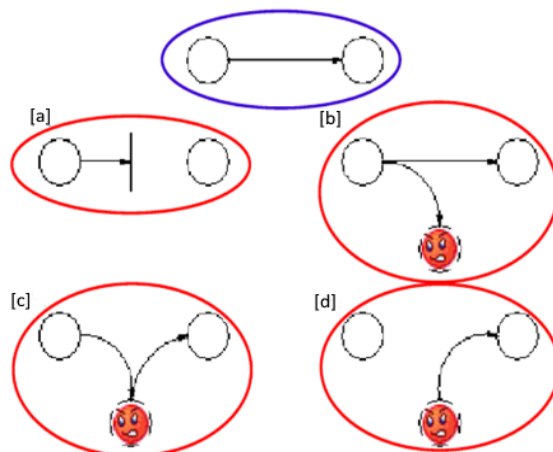
En seguridad informática, un ataque de denegación de servicio, llamado también ataque DoS (por sus siglas en inglés, Denial of Service), es un ataque a un sistema de computadoras o red que causa que un servicio o recurso sea inaccesible a los usuarios legítimos. El dDoS es la versión “dirigida” donde hay más de un atacante.

Botnet

Una botnet, u ordenadores “zombi” es una red de equipos infectados que se pueden controlar a distancia y a los que se puede obligar a enviar spam, propagar malware o llevar a cabo un ataque DDoS, y todo sin la autorización del dueño del dispositivo

02- Tipos de ataque

- **[a] Interrupción:** Ataque DoS
- **[b] Interceptación:** Sniffer
- **[c] Modificación:** Copiar info
- **[d] Fabricación:** Suplantación de identidad



02- Tipos de ataque

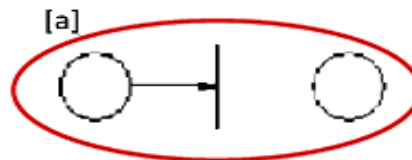
[02]

[a] Interrupción

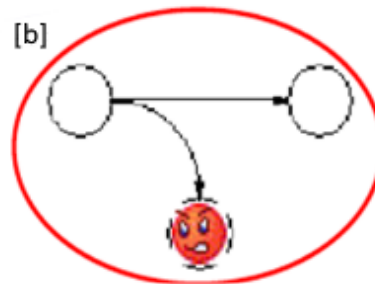
Hay un corte en la prestación de servicio.

Ejemplo:

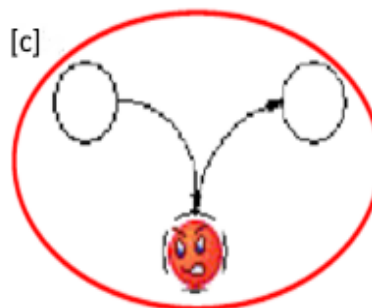
El servidor web no responde, el disco de red no aparece.

**[b] Interceptación**

Se tiene acceso a la comunicación y se copia la información transmitida.

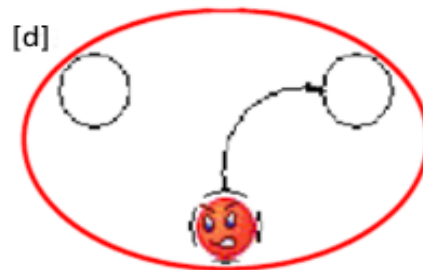
**[c] Modificación**

Acceso a la comunicación, y se modifica la información transmitida para provocar reacción anormal.



02- Tipos de ataque**[03]****[d] Fabricación**

El atacante se hace pasar por el emisor de la transmisión.

**03- Técnicas de ataque****Phishing**

Contactar con la víctima haciéndose pasar por una empresa con la cual tenemos relación. Intenta llevarnos a un enlace que lleva a una falsa web de empresa.

Keylogger

Troyano que registra las teclas que vamos pulsando y las envía al atacante.

Fuerza bruta

Generación automática de contraseñas, para intentar adivinarla.

Spoofing

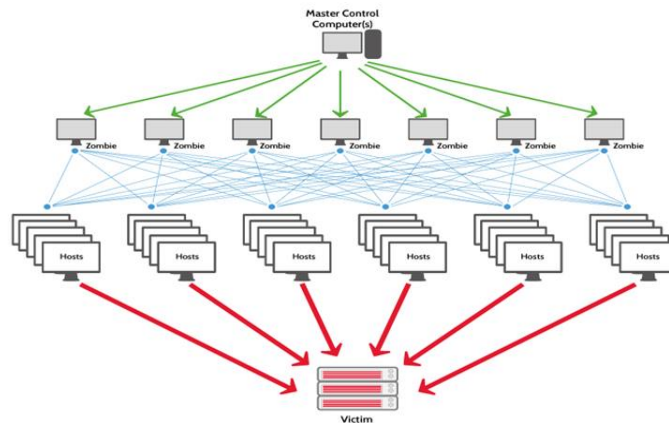
Hacernos pasar por otra máquina. Suplantación de identidad.

Sniffing

El atacante se conecta al mismo tramo de red que el equipo atacante, para monitorizar y analizar el tráfico de la red.

03- Técnicas de ataque**[02]****DoS**

(Denial of Service) detener un servidor saturándolo con falsas peticiones de conexión.

**DDoS**

(Distributed Dos) ataque DoS con muchas máquinas repartidas por diferentes lugares.

04- Terminología hacker**White Hat**

Hackers éticos que trabajan para empresas de seguridad para proteger los sistemas.

Black Hat

Ciberdelincuentes, atacan sistemas, roban información, crean malware...

Grey Hat

Híbrido, actúa ilegalmente, pero con buena intención.

Cracker

Robar información, colapsar servidores, infectar redes, entrar a zonas restringidas, ciberterrorismo.

Pharmer

Atacantes de phishing ("pescadores" con emails, mensajes...)

04- Terminología hacker**[02]**

Phreaker	Ataca sistemas tecnológicos, tecnologías móviles y sin hilos, etc.
Carder	Fraude con tarjetas de crédito.
Spammer	Spam y publicidad ilegal.
Hacktivista	Ataques políticos.
Newbie	Sin experiencia
Lamer	Se cree un hacker, pero no lo es.

05 – Motivaciones de los Hackers

- Consideraciones económicas.
- Diversión.
- Ideología.
- Autorrealización.
- Reconocimiento social o cierto status.

06- Exploits

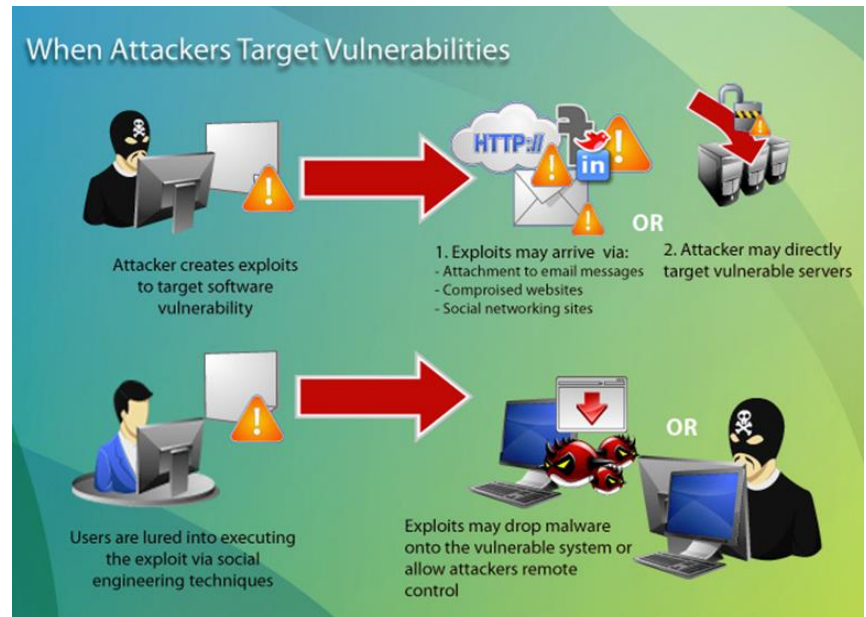
Un exploit es un ataque poco ético o legal que se aprovecha de vulnerabilidades en aplicaciones, redes o hardware. El ataque consiste en software o código que tiene como objetivo obtener el control de un sistema informático o robar datos guardados en red.

Ejemplo:

Acceso no autorizado, control del sistema, conseguir privilegios, ataques DoS, ingeniería social...

Como protegerse:

- Instalarse las actualizaciones y parches de seguridad.
- Tener el software y el SO actualizado.
- Tener un buen antivirus.
-



07- Herramientas empleadas durante un ataque

Escáner de puertos

Para detectar servicios instalados en el sistema local o en un sistema remoto.

Ejemplo:

Nmap

Sniffers o escuchadores de red

Para capturar datos.

Ejemplo:

Wireshark

Exploits

Buscan y explotan vulnerabilidades del sistema.

Backdoor o puerta trasera

Abren agujeros de seguridad dejando puertos abiertos.

07- Herramientas empleadas durante un ataque**[02]**

Rootkits	Para ocultar malware.
Auto-rooters	Para automatizar un ataque.
Password-crackers	Para averiguar las contraseñas de los usuarios (con técnicas de diccionario, fuerza bruta o ingeniería social).
Generador de malware	Para generar malware o virus.

08 – Hacking ético

La seguridad TI es una de las mayores preocupaciones de las empresas de hoy día. Además de contar con una completa plataforma de seguridad, capaz de proteger la infraestructura empresarial, el hacking ético se ha convertido en un servicio fundamental para detectar dónde está el peligro o la vulnerabilidad.

Protección de las empresas ante los ciberataques:

- Identificar y solucionar vulnerabilidades.
- Concienciar a los trabajadores de la importancia de la seguridad informática.
- Mejorar los procesos de seguridad.

09- Buenas practicas

- Localizar activos que se tengan que proteger.
- Política de copias de seguridad.
- Planes de actuación ante catástrofes.
- Instalar solamente el software estrictamente necesario.
- Actualizar automáticamente las aplicaciones.
- Formar a los usuarios.
- Revisar los logs del sistema (accounting).
- Contratar auditorías externas.
- Revisar la lista de equipos conectados.
- Revisar la lista de usuarios activos.
- Implementar estándar sobre seguridad informática (normas ISO 27000)
- Estar al corriente de vulnerabilidades.

Nuestro objetivo es proteger a nuestra empresa y clientes de los ciberataques

[UD 1-2 | 23-10-22 13:03]

Anexo pentesting:

Herramientas básicas auditoria seguridad SI

2- [Rastreo de exploits - Vulnerabilidades por NMAP]

CVE.MITRE.ORG

https://cve.mitre.org/cve/search_cve_list.html**[Nmap]:**

Con NMAP se pueden rastrear las vulnerabilidades tanto de rangos de IPs como de rangos de puertos. Este sistema no solo muestra las vulnerabilidades si no también información precisa, tanto de los sistemas operativos operando en los equipos, los servicios y su versión, así como los puertos que están abiertos.

Es importante recordar que el uso de esta herramienta siempre ha de ser realizado bajo conocimiento y previa autorización del administrador de la empresa/red donde se vaya a ejecutar. Su uso ilícito es considerado delictivo en la legislación española, así como en la amplia mayoría de países del mundo.

Scanner agresivo:**nmap -A -T5 -sV -O xxx.xxx.xxx.xxx/xx****Para un rango, definiendo como IP una dirección de red y su CIDR****nmap -A -T5 -sV -O -p1-65535 xxx.xxx.xxx.xxx/xx** **Para un rango y todos los puertos posibles.**

Detalle de parámetros:**[NMAP]**

-A	Ataque agresivo Máximo. [Análisis al máximo de velocidad]
-T5	Agresivo alto.
-T4	Agresivo medio.
-T2	Suave.
-T1	Muy suave, difícilmente detectable.
-T0	Modo extremadamente paranoico, indetectable. [El análisis puede llevar, días]
-sV	Sondear puertos abiertos, para obtener información de servicio/versión
-O	Activar la detección de sistema operativo (SO)

Scanner sencillo o básico:`nmap xxx.xxx.xxx.xxx`

(Un escáner muy sencillo que mostrara información de contacto)

Rastrear vulnerabilidades listadas en NMAP:

- 1- Seleccionamos la versión de la vulnerabilidad (indicada por un código)
- 2 - Entramos en CVE mitre, añadiendo ese código a "Search CVE List" copiamos el código tras el CVE-'XXXX-XXXX'
- 3- Clicamos en cualquiera de los resultados y tendremos acceso a las instrucciones para su explotación o a la ubicación de su exploit.
- 4 - Entramos en [exploit-db.com] pegamos el 'XXXX-XXXX' en el search avanced CVE [aquí]

Parámetros completos del NMAP [V.2022]

<https://nmap.org/man/es/man-briefoptions.html>

Uso: nmap [Tipo(s) de Análisis] [Opciones] {especificación de objetivos}

ESPECIFICACIÓN DE OBJETIVO:

Se pueden indicar nombres de sistema, direcciones IP, redes, etc.

Ej: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254

-iL <archivo_entrada>: Lee una lista de sistemas/redes del archivo.

-iR <número de sistemas>: Selecciona objetivos al azar

--exclude <sist1[,sist2][,sist3],...>: Excluye ciertos sistemas o redes

--excludefile <fichero_exclusión>: Excluye los sistemas indicados en el fichero

Parámetros completos del NMAP [V.2022]**[02]****DESCUBRIMIENTO DE HOSTS:**

-sL: Sondeo de lista - Simplemente lista los objetivos a analizar

-sP: Sondeo Ping - Sólo determina si el objetivo está vivo

-PO: Asume que todos los objetivos están vivos

-PS/PA/PU [listadepuertos]: Análisis TCP SYN, ACK o UDP de los puertos indicados

-PE/PP/PM: Solicita un análisis ICMP del tipo echo, marca de fecha y máscara de red

-n/-R: No hacer resolución DNS / Siempre resolver [por omisión: a veces]

--dns-servers <serv1[,serv2],...>: Especificar servidores DNS específicos

--system-dns: Utilizar la resolución del sistema operativo

TÉCNICAS DE ANÁLISIS:

-sS/sT/sA/sW/sM: Análisis TCP SYN/Connect()/ACK/Window/Maimon

-sN/sF/sX: Análisis TCP Null, FIN, y Xmas

--scanflags <indicador>: Personalizar los indicadores TCP a utilizar

-sI <sistema zombi[:puerto_sonda]>: Análisis pasivo («Idle», N. del T.)

-sO: Análisis de protocolo IP

-b <servidor ftp rebote>: Análisis por rebote FTP

ESPECIFICACIÓN DE PUERTOS Y ORDEN DE ANÁLISIS:

-p <rango de puertos>: Sólo sondear los puertos indicados

Ej: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080

-F: Rápido - Analizar sólo los puertos listados en el archivo nmap-services

-r: Analizar los puertos secuencialmente, no al azar.

Parámetros completos del NMAP [V.2022]**[03]****DETECCIÓN DE SERVICIO/VERSIÓN:**

-sV: Sondear puertos abiertos, para obtener información de servicio/versión

--version-intensity <nivel>: Fijar de 0 (ligero) a 9 (probar todas las sondas)

--version-light: Limitar a las sondas más probables (intensidad 2)

--version-all: Utilizar todas las sondas (intensidad 9)

--version-trace: Presentar actividad detallada del análisis (para depurar)

DETECCIÓN DE SISTEMA OPERATIVO

-O: Activar la detección de sistema operativo (SO)

--osscan-limit: Limitar la detección de SO a objetivos prometedores

--osscan-guess: Adivinar el SO de la forma más agresiva

TEMPORIZADO Y RENDIMIENTO:

-T[0-5]: Seleccionar plantilla de temporizado (los números altos son más rápidos)

--min-hostgroup/max-hostgroup <tamaño>: Paralelizar los sondeos

--min-parallelism/max-parallelism <numsondas>: Paralelización de sondeos

--min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <msecs>: Indica el tiempo de ida y vuelta de la sonda

--max-retries <reintentos>: Limita el número máximo de retransmisiones de las sondas de análisis de puertos

--host-timeout <msecs>: Abandonar un objetivo pasado este tiempo

--scan-delay/--max-scan-delay <msecs>: Ajusta el retraso entre sondas

Parámetros completos del NMAP [V.2022]**[04]****EVASIÓN Y FALSIFICACIÓN PARA CORTAFUEGOS/IDS:**

- f; --mtu <valor>: fragmentar paquetes (opc. con el MTU indicado)
- D <señuelo1,señuelo2[,ME],...>: Disimular el análisis con señuelos
N. del T.: «ME» es «YO» mismo.
- S <Dirección_IP>: Falsificar la dirección IP origen
- e <interfaz>: Utilizar la interfaz indicada
- g/--source-port <numpuerto>: Utilizar el número de puerto dado
- data-length <num>: Agregar datos al azar a los paquetes enviados
- ttl <val>: Fijar el valor del campo time-to-live (TTL) de IP
- spoof-mac <dirección mac/prefijo/nombre de fabricante>: Falsificar la dirección MAC
- badsum: Enviar paquetes con una suma de comprobación TCP/UDP falsa

SALIDA:

- oN/-oX/-oS/-oG <file>: Guardar el sondeo en formato normal, XML, s|<rlpt klddi3 (n3n3b4n4n4), y Grepeable (para usar con grep(1), N. del T.), respectivamente, al archivo indicado.
- oA <nombre_base>: Guardar en los tres formatos principales al mismo tiempo
- v: Aumentar el nivel de mensajes detallados (-vv para aumentar el efecto)
- d[nivel]: Fijar o incrementar el nivel de depuración (Tiene sentido hasta 9)
- packet-trace: Mostrar todos los paquetes enviados y recibidos
- iflist: Mostrar interfaces y rutas (para depurar)
- append-output: Agregar, en vez de sobrescribir, a los archivos indicados con -o.
- resume <archivo>: Retomar un análisis abortado/detenido
- stylesheet <ruta/URL>: Convertir la salida XML a HTML según la hoja de estilo XSL indicada
- webxml: Referenciar a la hoja de estilo de Insecure.Org para tener un XML más portable
- no-stylesheet: No asociar la salida XML con ninguna hoja de estilos XSL

Parámetros completos del NMAP [V.2022]**[05]****MISCELÁNEO:**

-6: Habilitar análisis IPv6

-A: Habilita la detección de SO y de versión

--datadir <nombreDir>: Indicar la ubicación de los archivos de datos Nmap personalizados.

--send-eth/--send-ip: Enviar paquetes utilizando tramas Ethernet o paquetes IP "crudos"

--privileged: Asumir que el usuario tiene todos los privilegios

-V: Muestra el número de versión

-h: Muestra esta página resumen de la ayuda.

EJEMPLOS:

```
nmap -v -A scanme.nmap.org
nmap -v -sP 192.168.0.0/16 10.0.0.0/8
nmap -v -iR 10000 -P0 -p 80
```

////////////////////////////////////

[Hydra - Medusa]

Hydra: script para realizar ataques de fuerza bruta en todo tipo de servicios.

hydra + enter muestra todo el help o man.

permite el ataque a servidores incluso definiendo puertos...

```
hydra -L user.txt -P pass.txt ssh://xxx.xxx.xxx.xxx -t 4
```

Parámetros completos del Hydra [V.2022]

- I Especifica el username utilizado durante el ataque de fuerza.
- L Especifica el username wordlist a usar durante el ataque de fuerza.
- p Especifica el password a utilizar durante el ataque de fuerza.
- P Especifica el password worlist a usar durante el ataque de fuerza.
- t Define el número de treats o hilos de trabajo en paralelo a emplear durante el ataque.

ssh: IP aquí definimos le servicio al que se ataca, separándolo por dos puntos y barras Linux antes de la IP.

Formato de los wordlist/users/passwords:

password01

password02

Se tienen que escribir de arriba hacia abajo, una palabra por línea, pegados al margen y a la parte sup.

pasworf03

Medusa:

Es lo mismo que hydra, aunque con una sintaxis diferente:

```
medusa -M ssh -U users.txt -P pass.txt -h 192.168.31.20
```

Parámetros completos del Medusa [V.2022]

-M	Identifica el modulo/servicio
-u	Username para probar
-U	Username wordlist para probar
-P	Pasword para probar
-P	Password wordlist para probar
-h	Host name /direction
-H	Host Wordlist para probar

Vitales pentesting:

<https://nmap.org/man/es/man-briefoptions.html>
https://cve.mitre.org/cve/search_cve_list.html
<https://www.exploit-db.com/>

[Google dorks]

cache:url.com	Buscaremos en el chache más reciente de la página.
allintext:texto	Buscará el texto o la palabra en cualquier página web que localice.
inurl:palabra	Buscara la palabra en la url.
filetype:.mp3	Buscara este tipo de archivo o extensión en especial.
intext:texto	Buscara una palabra en particular en los textos de la web.
site:url.com	Buscara en la url indicada y en toda su raíz o subdominios.
intitle:palabra	Buscara el contenido indicado en los títulos de las url web.
related:url	Buscara paginas similares.
link:enlace	Buscara sitios con ese enlace o similar.
allintitle:palabra	Buscara esas palabras exactas en el nombre de la página.
allinurl:palabra	Buscara sitios que tengan todas las palabras de búsqueda en la url.

[Google dorks]

Ejemplos:

allintext:username filetype:log

intitle:"index of" inurl:ftp

intitle:index.of mp3

filetype:txt site:web.com password|passwords|contraseñas|login|contraseña

filetype:sql "MySQL dump" (pass|password|passwd|pwd)

[Pentesting | 29-10-22 00:40]

UD2 – Legislación y normativa

Aspectos legislativos que afectan a la seguridad jurídica de las personas físicas que prestan datos para su tratamiento automático o intervienen en transacciones comerciales.

Und**02****RGPD (LOPD 2018)**

Reglamento general de protección de datos.

LSSICE

Leí de los servicios de la sociedad de la información y del comercio electrónico.

Normas ISO 27000

Estándares sobre Seguridad de la información.

LPI

Ley de la propiedad intelectual, derechos del autor en los entornos digitales.

1- Niveles de seguridad:**LOPD 2018**

		IMP
	Tipos de datos	Medidas de seguridad
Básico	Datos personales	Autenticación, control de acceso.
Mediano	Datos sobre personalidad, patrimonio, infracciones...	Medidas de nivel básico + Catálogo de medidas, autenticación remota y auditoria cada 2 años.
Alto	Ideología, creencias, salud, origen racial, vida sexual, datos biométricos o genéticos...	Medidas de nivel mediano + Criptografía.

1- Niveles de seguridad:**[Continuación]**

Datos Básicos	Nombre	LOPD 2018
	Apellidos	
	Direcciones de contacto (físicas o electrónicas)	
	Número de teléfono (fijo o móvil)	
	Número de cuenta corriente	
	Otros	
Medidas de seguridad obligatorias:		
	Documento de seguridad	
	Régimen de funciones y obligaciones del personal	
	Registro de incidencias	
	Identificación y autenticación de usuarios	
	Control de accesos	
	Gestión de soportes	
	Copias de seguridad y recuperación	

IMP

Datos intermedios	Comisión de infracciones penales	LOPD 2018
	Comisión de infracciones administrativas	
	Información de hacienda publica	
	Información de servicios financieros	

IMP

1- Niveles de seguridad:**[Continuación]****Medidas de seguridad obligatorias:****[Datos intermedios]****IMP**

Medidas de seguridad de nivel básico

Auditoria bianual

Medidas adicionales de identificación y autenticación de usuarios

Control de acceso físico

Medidas adicionales de gestión de soportes

Registro de incidencias

Pruebas sin datos reales

Datos Nivel alto

Ideología

Religión

Creencias

Origen racial

Salud

Vida

LOPD 2018

IMP**Medidas de seguridad obligatorias:**

Medidas de seguridad de nivel básico e intermedio

Seguridad en la distribución de soportes

Registro de accesos

Medidas adicionales de copias de soporte

Cifrado de telecomunicaciones

1- Niveles de seguridad:

[Continuación]

LOPD 2018

Nivel básico

Exigible en la gestión de todos los **ficheros de almacenamiento de datos de carácter personal**. Implantación de **medidas de autenticación y control de acceso** para los usuarios que han de acceder al fichero con contenido sensible. Elaboración de protocolos de actuación sobre el fichero.

Datos identificativos, NIF, número de la SS, nombre y apellidos, teléfonos, imagen personal, email, nombre de usuario, cuenta corriente, matrícula...

Nivel mediano

Elaborar un **catálogo sobre las medidas de seguridad genéricas** que se han de llevar a cabo e implementar mecanismos de **autenticación remota** seguros. A demás, estas medidas se tienen que someter como mínimo, cada dos años a una **auditoria externa**.

Datos sobre la personalidad (gustos, aficiones...) , información sobre patrimonio, datos sobre delitos o infracciones...

Nivel alto

Para proteger los ficheros situados en este nivel hacen falta **métodos criptográficos** para evitar que los datos sensibles sean legibles y puedan ser alterados o capturados mientras circulen por una red.

Datos relativos a ideología, creencias, origen racial, salud, vida sexual, u obtenidas con finalidades policíacas, datos biométricos o genéticos.

2- RGPD

Lo que conocíamos como LOPD 2018 en España es el RGPD (o GDPR General data protection regulation) de ámbito europeo. Es una normativa que regula la protección de datos del consumidor y que sustituye a la antigua LOPD.

Todos los países de la UE están obligados a cumplirla. Así como todos los países de fuera de la UE que traten con datos de ciudadanos de la UE.

IMP**3- ¿Quién ha de cumplir la RGPD?**

Está obligada a cumplirla cualquier persona física o jurídica que realice una actividad económica y procese datos personales.

IMP**4- Características del RGPD****IMP**

Derechos del individuo	Amplia los derechos de las personas físicas y la información que deben recibir sobre el tratamiento de sus datos.
Consentimiento	Debe ser una declaración u otra acción afirmativa clara. No se puede dar por supuesto ni siquiera usar casillas ya marcadas en una web.
Delegado de protección de datos	Ha de ser obligatorio. Debe estar especializado en la legislación de protección de datos. Puede ser un empleado o subcontratado.
Sanciones	Pueden llegar al 4% de la facturación anual mundial o a 20 millones de euros, lo que sea mayor. La sanción puede imponerse, aunque no haya pérdida en sí de los datos.
Portabilidad de los datos	Las personas tienen ahora el derecho a mover, copiar o transferir sus datos, incluso a una empresa de la competencia.

4- Características del RGPD

[Continuación]

IMP**Comunicación obligatoria de las violaciones de seguridad**

Los responsables de los datos deben informar a la autoridad de control (AEPD en España) en el plazo de 72 horas desde su conocimiento. En violaciones graves de la seguridad, hay que informar a los interesados.

Ámbito de aplicación mayor

Afecta a las empresas y a quienes se encarguen del tratamiento de datos para ellas, incluso fuera de la UE.

Privacidad de principio a fin

La privacidad debe tenerse en cuenta en todo y solo pueden usarse los datos estrictamente necesarios para el fin estipulado.

5- Principios clave del RGPD**IMP****Seguridad****Art.32 Seguridad del tratamiento**

El encargado del tratamiento aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo...

Consentimiento**Art.4 Apartado 11, sobre gestión de consentimientos**

Toda manifestación de voluntad libre, específica, informada e inequívoca por la que el interesado acepta, ya sea mediante una declaración o una clara acción afirmativa.

Derecho al olvido**Art.17 Derecho de supresión o derecho al olvido****Portabilidad****Art.20 Derecho a la portabilidad de datos**

El interesado tendrá derecho a recibir los datos personales que le incumban, que haya facilitado a un responsable del tratamiento o, en un formato estructurado, de uso común y lectura mecánica, y a transmitirlos a otro responsable del tratamiento...

6- Implicaciones del RGPD

Territorio de aplicación UE y empresas de fuera que traten datos de personas de la UE.

Avisos de seguridad Especificar base legal, tiempo de retención de datos, información clara.

Consentimiento del usuario Únicamente de los datos necesarios para dar su servicio/producto.
El consentimiento ha de ser activo y verificable, no darlo por supuesto.

Consentimiento parental En el tratamiento de información de menores.

Derecho al olvido El usuario puede solicitar la eliminación de los datos.

Cancelación de datos Solamente se conservaran el tiempo estrictamente necesario.

Derecho a la portabilidad de los datos

Registro obligatorio de los datos

Estudiar los riesgos antes de hacer modificaciones.

Responsable de protección de la información Obligatorio nombrar a un DPO (Data protection officer.)

7-¿Qué más puede implicar?

- Auditorias de todos los procesos de todos los departamentos (sobre todo procesos críticos) Mejor si son auditorías externas.
- Formación del personal.
- Adaptación de los sistemas informáticos.
- Designación y formación de un delegado de protección de datos (obligatorio para organismos públicos, empresas que hagan seguimiento de personas a gran escala, incluyendo la elaboración de perfiles o datos especiales, médicos, de condenas o infracciones penales...)
- Establecer y mantener procesos continuos de documentación para demostrar el cumplimiento del RGPD.
- Certificación (voluntaria)
- Indemnizaciones por daños y perjuicios.

8-Seguridad de los datos:

Los datos se tienen que procesar de forma que se garantice su seguridad. Protegerlos del procesamiento no autorizado o ilegal y de la pérdida accidental, destrucción o daño.

Se tienen que comunicar a los usuarios cualquier violación de datos.

- 1- **Evaluación de riesgos**, para establecer medidas técnicas y organizativas para garantizar la seguridad.
- 2- **Establecer políticas de tratamiento de datos.**
- 3- **Formar y concienciar a los empleados.**

A diferencia de la antigua LOPD, en la RGPD no se especifica un catálogo específico de medidas de seguridad a aplicar.

Medidas de seguridad sugeridas:

- Backups (copias de seguridad) + encriptación.
- Enviar Backups por canales seguros (VPN)
- Antivirus actualizado, centralizar los antivirus.
- Control de accesos, contraseñas (compleja cambiar cada 3 meses) firewall (con capa extra de filtrado de contenidos).
- Seudonimización y cifrado.
- En caso de incidencia, capacidad de restaurar la disponibilidad de los datos y su acceso en un tiempo razonable.

9-LSSICE**Legislación sobre los servicios en la sociedad de la información y el comercio electrónico****IMP****Afecta a:**

- Todo servicio que se da a distancia, por medios electrónicos y a petición individual del destinatario.
- Compra y venta de productos o servicios por internet o una red pública electrónica o similar (eCommerce)
- Entidades intermediadoras. Operadores de telecomunicaciones, proveedores de servicios de internet (ISP), servicios de almacenamiento de datos, buscadores...
- Para evitar el mal uso de la tecnología.

10- LSSICE – eCommerce**IMP****Se tiene que mostrar en la web:**

Datos de la empresa	NIF, denominación social, domicilio, email teléfono, inscripción en el registro mercantil...
Precios	De los productos o servicios, indicando claramente si incluyen impuestos o gastos de envío.

Si hacen contratos online:

- Trámites a seguir, condiciones legales, idioma del contrato, medios para corregir errores...
- Confirmación electrónica con justificante de recepción.
-

Si se hacen comunicaciones electrónicas:

- Identificar claramente la empresa o entidad.
- Si es publicidad, tiene que contener palabras “publicidad” o “publi”.
- En ofertas, concursos o juegos, identificar la finalidad y las condiciones de participación.
- Establecer procedimientos sencillos para que el usuario se pueda dar de baja del servicio.

11- LSSICE – Intermediarios

- Han de informar a sus clientes de los medios para argumentar la seguridad (antivirus, antispam...) y de las herramientas para filtrar y restringir el acceso a contenidos y servicios.
- Las entidades no son responsables de los contenidos que transmiten o alojan si no han participado en su elaboración.
- En caso de que el contenido sea ilícito, han de retirarlo e imposibilitar su acceso.

12- LSSICE – Páginas web

Los usuarios con página web y que perciban ingresos tiene que mostrar en la web:

- Nombre y apellidos.
- Datos de contacto (dirección postal, email, teléfono...)
- NIF.

Y sobre la publicidad:

- El anunciante se tiene que identificar claramente.
- Se tiene que especificar que es publicidad.

13- LSSICE – Garantías y derechos de los usuarios

- Conocer la identidad del que ofrece el servicio (nombre, dirección, NIF/CIF...)
- Conocer los precios de los artículos, impuestos y gastos de envío antes de formalizar un contrato.
- Conocer las condiciones generales antes de una contratación.
- Conocer los pasos necesarios para la contratación.
- Recibir un justificante del vendedor confirmando la recepción del pedido.
- No recibir publicidad no solicitada y poder dejar de recibir la que haya autorizado.
- Protección en compras a distancia.

14- ISO 27000

La **ISO 27000** es un conjunto de estándares internacionales sobre la **seguridad de la información**. La familia ISO 27000 contiene un conjunto de buenas prácticas para el establecimiento, implementación, mantenimiento y mejora de sistemas de gestión de la seguridad de la información (SGSI).

Las más importantes son la **27001** y la **27002**.

15- Nomas ISO/IEC 27000

27001 – Especificaciones de un SGSI (sistema de gestión de la seguridad de la información).

27002- Código de buenas prácticas.

16- LPI | Ley de propiedad Intelectual

- Establece los derechos de autor en los entornos digitales.
- Digitalización es un acto de reproducción: es necesaria la autorización expresa del titular del contenido.
- Excepción: Copia privada. No se puede utilizar de modo colectivo ni lucrativo.
- Establece un canon sobre los dispositivos de almacenamiento que revierte sobre las sociedades de autores.

17- Nueva ley de copyright europea**Regulación de los derechos de autor en internet**

- La comisión europea crea en 2016 la directiva sobre los derechos de autor en el mercado único digital, o abreviando; directiva de derechos de autor de la unión europea.
- La directiva se aprueba el 26 de marzo de 2019, no sin polémica.
- Los artículos más polémicos fueron el 11 y el 13, cambiados finalmente por 15 y 17.
- Los usuarios quedan exentos del cumplimiento de la norma y todo el peso recae en las plataformas.

17- Nueva ley de copyright europea**Regulación de los derechos de autor en internet****[Continuación]**

- El artículo 15 –antes artículo 11- establece unas tasas sobre los mismos enlaces, una especie de “tasa google” que podría afectar a todos los lugares web con un volumen considerable.
- El artículo 17 – antes articulo 13 o “anti memes” - es el que fuerza a los lugares a aplicar filtros de subida que controlen el contenido que alojan sus usuarios, y que en la medida de lo posible adquieren los derechos necesarios para la reproducción de los contenidos.

Artículo – 15

- Regula la utilización digital de las publicaciones de prensa. Es una especie de Canon AEDE europeo (Canon exigido para enlazar contenido protegido por derechos de propiedad intelectual).
- Prohíbe que se comparta cualquier tipo de creación o noticia periodística que este protegida por derechos de propiedad intelectual y se da opción a los editores de prensa para que gestionen con terceras personas los derechos de autor. Así las plataformas de internet tendrán que solicitar la autorización a cada autor de artículos de prensa, para poder incluir su contenido.
- La finalidad es imponer a estas plataformas en línea un canon por incluir enlaces a noticias, de modo que los editores obtengan unos ingresos por esto.
-

Artículo – 17

- Impone la obligación a las páginas web de supervisar los contenidos subidos en sus plataformas por los usuarios para garantizar que no se “infringen los derechos de autor”.
- Las principales plataformas de video como Vimeo o YouTube solo controlan el contenido subido cuando hay un aviso de infracción por copyright. Con este artículo, pero, tendrán que crear filtros previos que impidan la subida de contenidos protegidos por derechos de autor.
- Estas plataformas han de aplicar sistemas que les permitan detectar infracciones de derechos de autor previamente a subir el contenido a la red. YouTube ya tiene una herramienta para este propósito que se denomina Content ID.

18- Regulación de los derechos de autor en internet

A partir de ahora, las plataformas digitales (Meta, Google...) tendrán que aplicar filtros de contenidos para detectar infracciones de vulneración del copyright.

Monitorización masiva de los contenidos**Canon (link tax) para poder compartir enlaces con propiedad intelectual**

Nueva obligación jurídica para que los proveedores de internet utilicen tecnologías de supervisión para detectar materiales protegidos por los derechos de autor, y tecnologías de filtrado para bloquear las cargas que infringen su copyright.

19 – Código penal

Una gestión incorrecta de la información relacionada con datos personales o íntimos puede implicar sanciones (multas) o ser considerada como una acción ilegal contra la ley.

Por esto, los usos e implantación de los sistemas informáticos se tienen que adaptar a la ley vigente en el país.

Riesgo de sanciones graves o penas privativas de libertad**Ejemplos:**

Acceso no autorizado en un sistema informático	Delito de intrusión
Pharming, phishing, ingeniería social	Delitos de fraude informático
DoS	Delito de daños
Copiar, interceptar información, datos, emails...	Delito contra la intimidad
Descarga o intercambio de contenido protegido	Delito contra la propiedad intelectual

Anexo**Anonimización**

Desvincular completamente los datos personales de los datos identificativos, haciendo imposible que a través de esos **datos anonimizados** se pueda identificar o reidentificar al individuo.

Seudonimización

Desvinculación parcial de los datos personales. Generalmente, dividiéndolos en dos archivos diferentes. De modo que son necesarios datos de archivos diferentes para poder identificar al individuo.

Muro de cookies

Un muro de cookies es una forma que tienen las páginas web de denegar el acceso a sus usuarios si no consienten el uso de todas las cookies y rastreadores presentes en dicha página web. Es una barrera que pone al usuario en una situación del tipo “o lo tomas o lo dejas”, donde debe o aceptar las cookies de marketing y tecnologías de seguimiento similares, o se le denegará el acceso por completo al sitio web y a sus servicios.

Está prohibido en la UE , los muros de cookies no cumplen con el RGPD,

[12-11-22 21:43]

Anexo 02:**1-Conceptos del RGPD**

Para entender bien la RGPD primero tendremos que definir algunos conceptos básicos:

Datos personales Es cualquier información relacionada con un individuo, referida a su vida privada, profesional o publica, que lo **identifique**.

Decimos **identificable** o que **la persona es identificable** cuando esta puede ser identificada mediante un identificador como un “nombre”, identificador de “datos de geolocalización”, identificador “en línea” o uno o varios elementos propios de su identidad física, fisiológica, genética, psíquica, económica, cultural o social de esa persona.

Ejemplos: nombre, domicilio, foto, correo, detalles bancarios, publicaciones en redes, información médica o dirección IP.

No pretende aplicarse al tratamiento de datos personales para las actividades de seguridad nacional o aplicación de la ley en la UE (policía, defensa nacional, etc).

Tampoco afecta a personas particulares.

Interesado Es la persona física sometida al tratamiento de datos.

Fichero Es el conjunto organizado de datos de carácter personal, sea como sea que se cree, almacene, organice o se acceda.

Controlador de datos Es la entidad que determina los “propósitos y medios de procesamiento” o, en términos sencillos, como y porque se procesaran los datos personales.

1-Conceptos del RGPD**[Continuación]**

Responsable del tratamiento (RT)	Es la persona física o jurídica, autoridad pública, servicio u organismo que, solo o conjuntamente con otros corresponsables, determina la finalidad y medios para el tratamiento.
Encargado del tratamiento (ET)	Es la persona física o jurídica, autoridad pública, servicio u organismo que, solo o conjuntamente con otros encargados, trata los datos por cuenta del RT.
Delegado de protección de datos (DPO)	Es la persona encargada de informar y asesorar al RT de sus obligaciones relativas a la protección de datos.
Autoridad de control (AC)	Es la autoridad pública independiente con la función de supervisar la aplicación del reglamento.

2-¿Cuándo se aplica la RGPD?

A la pregunta de cuando se aplica la RGPD, la respuesta es cuando el controlador de los datos o responsable de datos, el encargado del tratamiento o el interesado tienen su sede en la UE.

También las organizaciones con sede fuera de la UE si recopilan o tratan datos personales de residentes en la UE.

3-Categorías de los datos en la RGPD

Aunque la RGPD no ofrece una definición sobre cuáles son las categorías de datos personales, si atendemos al artículo 9 del RGPD, aquí podemos ver que nos habla del “tratamiento de categorías especiales de datos personales”, mientras que el artículo 10 lo hace del “tratamiento de datos personales relativos a condenas e infracciones penales”, por lo cual, al menos, la normativa sí que parece distinguir entre diferentes categorías:

RGPD - Datos de carácter “general”

- Datos identificativos (nombre, DNI, número de la seguridad social, teléfono, dirección, firma, nombre de usuario, dirección IP, etc.).
- Características personales (características físicas, preferencias, aficiones, fecha de nacimiento, etc.).
- Circunstancias familiares y sociales (nombre de los hijos, permisos, licencias, etc.).

3-Categorías de los datos en la RGPD

RGPD - Datos de carácter “general”

[Continuación]

- Información laboral (categoría profesional, lugar de trabajo, experiencia profesional, nomina, etc.).
- Académicos y profesionales (formación, títulos, historial académico, etc.).
- Control de presencia.
- Financieros (ingresos, rentas, datos bancarios, etc.).
- Actividades y negocios

RGPD - Datos de categorías “especiales”

- Origen étnico o racial.
- Opiniones políticas, convicciones filosóficas o religiosas.
- Afiliación sindical.
- Genéticos (cualquier información relativa a las características genéticas de la persona, incluidos los análisis de ADN o ARN y siempre que los datos no se hayan anonimizado).
- Biométricos dirigidos a identificar de manera inequívoca una persona física (reconocimiento facial, escáner de iris, análisis de retina, reconocimiento de voz, huella digital, análisis de la firma, etc.).
- Relativos a la salud (todo dato relacionado con la salud física o mental de la persona; enfermedades, lesiones, resultado de pruebas o exámenes médicos, etc.).
- Relativos a la vida sexual o la orientación sexual.

El tratamiento de los datos de categorías especiales está totalmente prohibido, aunque existan algunas excepciones previstas por el artículo 9 del RGPD.

RGPD – Datos personales de naturaleza penal

Son aquellos datos que hacen referencia a denuncias, procedimientos judiciales o sentencias condenatorias. **Estos datos no se consideran sensibles**, pero tampoco ordinarios, ya que para su tratamiento han de tener una serie de reglas.

Los datos personales de naturaleza penal, **solamente pueden ser tratados cuando se tiene una base legal** (por ejemplo, un abogado en prestación de sus servicios) o el tratamiento lo lleva a término una autoridad legal u oficial. Así mismo, solo se puede llevar un registro completo de condenas penales bajo el control de las autoridades oficiales.

4-Base legal para el tratamiento

Los datos solamente se pueden tratar si existe al menos una base legal para llevarlo a cabo:

- El interesado ha dado su consentimiento para el tratamiento de sus datos personales con uno o más propósitos específicos.
- Es necesario para la ejecución de un contrato del cual el interesado es parte o para tomar medidas a petición del interesado antes de celebrar un contrato.
- Es necesario para cumplir con una obligación legal en la cual el controlador no está sujeto.
- Es necesario para proteger los intereses vitales del interesado o de otra persona física.
- Es necesario para la realización de una labor de interés público o en el ejercicio de la autoridad oficial conferida al controlador.
- Es necesario para los fines de los intereses legítimos perseguidos por el responsable o por un tercero, excepto cuando sean anulados por intereses o derechos y libertades fundamentales del interesado que requieran protección de datos personales, en particular cuando se trata de un niño.

5-Principios del tratamiento

Los principios de la protección de datos se tienen que aplicar a toda la información relativa a una persona física identificada o identificable.

- Licitud, lealtad y transparencia
- Limitación de la finalidad.
- Minimización de los datos.
- Exactitud.
- Limitación del termino de consentimiento
- Integridad y confidencialidad.
- Responsabilidad proactiva.

6-Obligaciones del RT

Dentro de las obligaciones que tiene el RT en referencia a los datos que trata, tenemos:

- Documentación / registro de los tratamientos.
- Aplicar las medidas adecuadas.
- Privacidad por defecto y desde el diseño.
- Evaluación del impacto de la privacidad.
- Seguridad y análisis de riesgos.
- Notificación de incidentes.
- Designación de DPO.
- Notificación de los fallos de seguridad.

7-Principio de consentimiento

Cuando el consentimiento se emplea como la base legal para el tratamiento, tiene que ser **explícito por los datos recopilados y los fines por los cuales se emplean**.

El consentimiento para niños ha de ser otorgado por **el padre o tutor** del niño y tiene que ser **verificable**. Los controladores de los datos tienen que poder probar el “consentimiento” y este puede ser retirado.

La gestión del consentimiento de la RGPD tiene implicaciones para las empresas que graban llamadas:

Los avisos del tipo “esta llamada está siendo grabada por motivos de seguridad” ya no serán suficientes para obtener el consentimiento. Cuando la grabación haya comenzado, si la persona que es grabada retira su consentimiento, el agente que recibe la llamada tendrá que detener la grabación previamente iniciada y se ha de asegurar de que no se guarde.

8-Derechos fundamentales de los interesados

El RGPD otorga varios derechos a los interesados, mediante los cuales pueden realizar una solicitud específica, para asegurarse de que sus datos personales no van a ser empleados con fines que no sean el objetivo legítimo, por el cual fueron proporcionados originariamente.

Derecho a la información

Derecho de acceso

Derecho de rectificación

Derecho a retirar el consentimiento

Derecho de oposición

Derecho de oposición al tratamiento automático

Derecho al olvido

Derecho a la portabilidad de datos

9-Medidas de seguridad para evitar fugas, violaciones e incidentes

Con tal de evitar fugas de seguridad, violaciones o incidentes con los datos, nos podemos adelantar, la RGPD recomienda tomar medidas que las eviten. Por esto recomiendan:

Medidas lógicas

- Antivirus y antimalware.
- Firewall.
- Cifrado.
- Seudonimización.
- Autorización y login.

Medidas físicas

- Protección en los inmuebles.
- Cámaras de seguridad.
- Personal de seguridad.
- Disposición de pantallas con datos no a la vista de otras personas o uso de filtros.

10- RGPD y Ciberseguridad (I)

Para poder demostrar el cumplimiento con el RGPD, el controlador de los datos tiene que implementar medidas que cumplan con los principios de protección de los datos por diseño y protección de los datos por defecto.

La privacidad por diseño y por defecto requiere que las medidas de protección de datos estén diseñadas para el desarrollo de procesos comerciales para productos y servicios (ciclo de vida de la seguridad alineada con el ciclo de vida del sistema y de la información).

Por esto se tiene que llevar a cabo un “Privacy impact Assesment” o “Análisis de impacto de la privacidad previo”, que determinara las amenazas existentes para estos datos y su nivel de impacto y probabilidad, lo cual determinara las salvaguardas necesarias.

10- RGPD y Ciberseguridad (I)**[Continuación]**

El reglamento a demás establece diferentes criticidades de acuerdo con el tipo de información gestionada (por ejemplo, los datos de salud, creencias u orientación sexual son de los más elevados) y el número de registros gestionados (impacto por volumen).

Cuando el tratamiento lo lleva a cabo una autoridad pública o cuando en el sector privado, el tratamiento lo lleva a cabo un controlador y las actividades centrales del mismo consisten en operaciones de tratamiento que requieren de la regulación y supervisión sistemática de los interesados, una persona con conocimientos expertos de la legislación y prácticas de la protección de datos, tendría que ayudar al controlador o procesador a supervisar el cumplimiento interno de este reglamento; el DPO (Delegado de protección de datos /Data privacy officer).

11- RGPD y Ciberseguridad (II)**Seudonimización de datos**

Tratamiento de datos personales de modo que no se puedan atribuir a un interesado sin utilizar información adicional. Dicha información adicional a de figurar a parte y tiene que estar sujeta a medidas técnicas y organizativas que garanticen que los datos personales no se atribuirán a una persona física identificada o identificable.

Esto se puede lograr mediante el uso del cifrado, enmascaramiento o la tokenitzacion el RGPD incluye la obligación de gestionar los incidentes que afecten a los datos personales y a notificar a la agencia estatal correspondiente (AEPD en el caso de España) determinadas brechas:

- Si la brecha puede causar daños emocionales, físicos o financieros.
- Si el volumen o la naturaleza de los datos así lo exigen.
- Si se trata de datos sensibles.

Esta notificación se tiene que realizar como mucho 72 horas después de haber tenido constancia de dicho incidente, a menos que sea improbable que dicha violación constituya un riesgo para los derechos y libertades de las personas físicas.

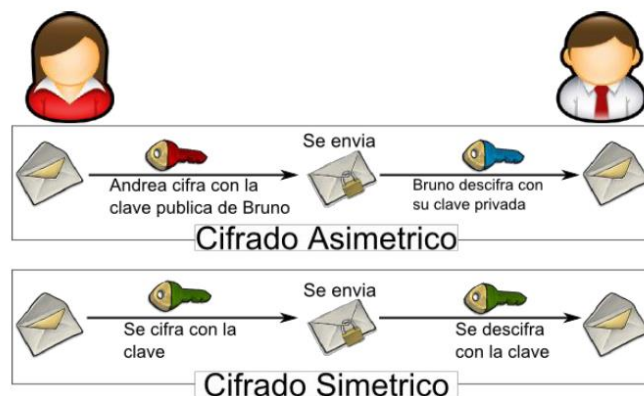
[13-11-22 00:20]

1-Criptografía

Herramientas criptográficas:

-Transposición: Cambio de posición de los símbolos.**-Sustitución:** Cambiar los símbolos por otros.**Algoritmos de cifrado:**

- **Criptografía simétrica** (1 Clave privada por persona).
- **Criptografía asimétrica** (2 Claves publicas + privada por persona).

**Resumen:****Criptografía simétrica** Una sola clave compartida entre el emisor y le receptor.**Criptografía asimétrica** Una pareja de claves(dos) para el emisor y una pareja de claves (dos) para el receptor.**2-Criptografia simétrica (Clave privada)**

Utilizamos la misma clave para cifrar y descifrar (Clave simétrica).

Funcionamiento: El emisor quiere hacer llegar un documento al receptor. Toma el documento y le aplica un algoritmo simétrico, empleando la clave única, que también conoce el receptor.

Ejemplos:

DES (poco seguido), **3 DES** (Triple DES), **RC5**, **AES**(El más seguro empleado por ahora),**Blowfish** e **IDEA**.

2-Criptografía simétrica (Clave privada)**[Continuación]****Ventajas**

Rápidas y eficientes. Apropriadas para cifrar grandes volúmenes de datos.

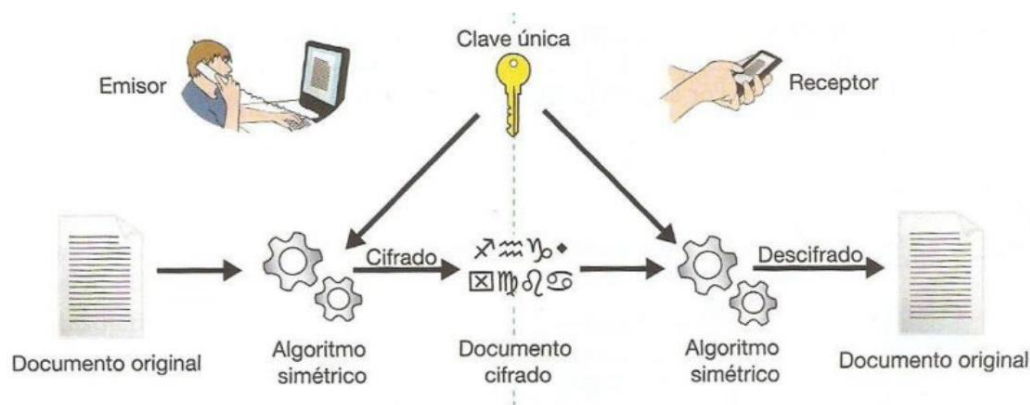
Inconvenientes

Vulnerables a ataques de fuerza bruta > la fortaleza de la clave es fundamental.

Se necesita una clave diferente para cada pareja de interlocutores.

Es necesario un canal seguro para enviar la clave.

Difícil gestionar muchas claves. (ejemplo: gran empresa), cada trabajador necesitaría 1 clave y un canal seguro.



A más longitud tenga la clave, mas segura:

Ejemplo:

Clave de 8bits > 2 elevado a 8 = 256 posibles claves > bastan 256 pruebas para descifrarla.

Clave de 256 bits > 2 elevado a 256 > (...), muchísimo más difícil de descifrar.

Como el algoritmo de la clave es público, basta con conocer la clave para romper el sistema de cifrado.

Algoritmos:

- DES (Data Encryption Standard): claves de 56 bits > Poco seguro.
- 3DES (Triple DES): Claves de 56 bits > Poco seguro.
- AES (Advanced Encryption Standard): Claves de hasta 256 bits > Más robusto.
- RC4 / SEAL / WAKE: Algoritmos de cifrados flojos. (Generan salidas según llegan bits).

3-Criptografía asimétrica (Clave pública)

En criptografía asimétrica se emplean dos claves matemáticas que están relacionadas entre sí; la pública y la privada.

Cada usuario tiene asociada una pareja de claves [Pu,Su]

[Pu] Publica Accesible para todos los usuarios de la red, suele aparecer en un directorio público.

[Su] Privada Tan solo es conocida por el usuario (es decir, el usuario propietario de la pareja de claves).

No se puede obtener la clave privada a partir de la clave pública.

Lo que se cifra con una solo puede ser descifrado con la otra:

Cifrado con la publica > Descifrado con la privada.

Cifrado con la privada > Descifrado con la pública.

Funcionamiento:

Cuando el usuario [A] desea enviar un mensaje al usuario [B], cifra el mensaje empleando la clave pública de [B] (conocida por los dos usuarios del criptosistema). Cuando el receptor [B] recibe el mensaje, únicamente lo podrá descifrar el mismo, utilizando su propia clave privada (la cual se encuentra exclusivamente en su poder, convenientemente protegida).

Algoritmos:

-RSA (Rivest Shamir Adleman): El más utilizado (aunque no es 100% seguro).

-DSA (Digital Signature Algorithm)

-Diffie-Hellman.

-RC4

El emisor tiene que comunicar su clave pública para que cuando el receptor tenga el mensaje, pueda descifrarlo. La clave pública se puede entregar a cualquier persona, la clave privada se tiene que guardar de modo que nadie tenga acceso a ella.

3-Criptografía asimétrica (Clave pública)**[Continuación]**

La criptografía asimétrica resuelve dos problemas de la clave simétrica:

- No necesita canales seguros para comunicar la clave que utilizemos en el cifrado.
- No hay problemas de espacio para guardar las claves. Todos los usuarios emplean el mismo canal y la clave pública propia.

Aun así, los algoritmos asimétricos tienen sus propios problemas:

- Son poco eficientes, lentos de aplicar por su longitud.
- Los mensajes cifrados son mucho mas grandes que los originales.
- Se necesitan claves mas grandes que en la criptografía simétrica.
- Utilizar las claves privadas repetidamente es arriesgado, porque algunos ataques criptográficos se basan en analizar paquetes cifrados.
- Hay que proteger la clave privada. Esta se guarda en un Keyring y el fichero está protegido mediante cifrado simétrico. Tendríamos que hacer muchas copias de seguridad del llavero.
- Hay que transportar la clave privada. Si no, no podremos descifrar archivos.

**4-Tarjeta inteligente (Smart-card)****[Adicional]**

La solución mas común a los problemas de proteger y transportar la clave privada es la tarjeta inteligente. Es una tarjeta de plástico que contiene un chip electrónico.

Dos tipos:

Tarjeta de memoria

Equivalente a una memoria flash, se limita a enmascarar la clave. Pide una clave simétrica.

Tarjeta procesadora/criptográfica

Guarda nuestras claves y nunca salen de la tarjeta. Cualquier cifrado que necesite nuestra clave privada es realizado por el mismo chip, porque incluye una CPU, memoria RAM... También pide una clave simétrica. Ejemplos: DNle, SIM...

5-Sistema híbrido

El sistema asimétrico es más lento y no sirve para cifrar los paquetes de una red de comunicaciones. Por esto se emplea un sistema híbrido.

Criptografía asimétrica para el inicio de sesión

+

Criptografía simétrica durante la transmisión, utilizando la clave acordada en el inicio de sesión.

****Los sistemas híbridos más importantes son PGP.GnuPG y OpenPGP para encriptar emails.**

6-Funcion Hash

En la criptografía asimétrica, el mecanismo de firma garantiza que el emisor es quien dice ser, pero para esto el emisor aplica una función hash en el documento > cifra esta función con su clave privada y lo envía al destinatario juntamente al documento original.

El valor hash identifica, prácticamente de manera inequívoca cualquier fichero (es como su ADN)

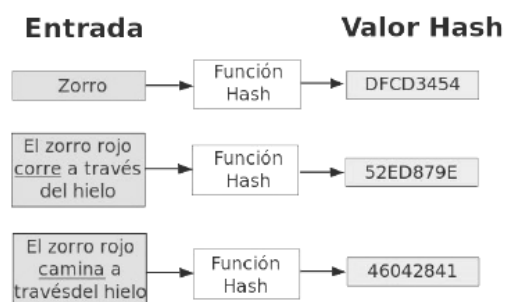
El destinatario hace dos operaciones:

- Aplica la misma función hash en el documento para obtener su resumen.
- Descifra el resumen recibido, utilizando la clave pública del emisor.

Si las dos funciones hash coinciden se garantiza el mensaje.

Un hash es un resumen de un documento o mensaje calculado con un algoritmo de hashing. Tienen como resultado una lista limitada de caracteres (normalmente 32-64 bits). Si cambiamos el documento de origen, cambia el hash.

No necesita una clave extra como los algoritmos de cifrado.



Cualquier pequeño cambio en el fichero hará que el hash cambie. También comprimido.

6-Funcion Hash**[Continuación]**

El hash también sirve para comprobar si un fichero a estado alterado (comprobar la integridad y la autenticidad).

Checksum > comprobar la integridad de una imagen.

Algoritmos más comunes:**MD5, SHA-1, SHA-256**

SHA-256> Recomendado por ser más seguro.

sha256sum [nombre_archivo]

MD5> Menos seguro pero rápido.

md5sum [nombre_archivo]

CRC32> Menos seguro.

cksum

7-Firma digital y Certificados electrónicos**Firma digital**

La firma digital permite al receptor de un mensaje verificar la autenticidad del origen de la información, así como verificar que esta información no ha sido modificada desde su generación.

Asegurar autenticidad, integridad y no repudio en los documentos electrónicos.

Emplear Internet de forma segura en la administración electrónica y el comercio electrónico.

Firmar un mensaje consiste en adjuntar con él un hash del propio mensaje.

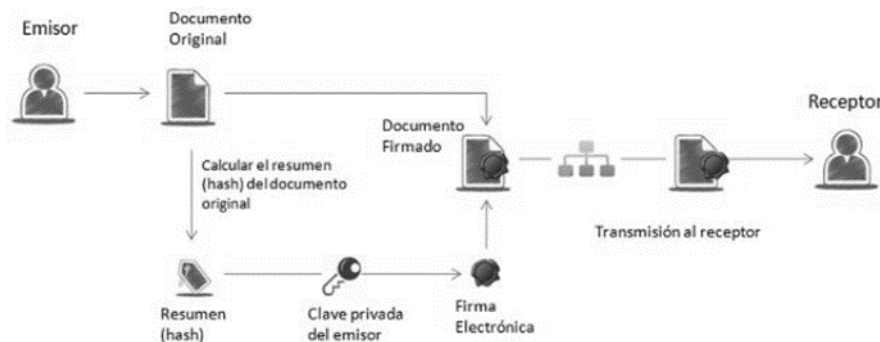
El destinatario vuelve a calcular el hash con la misma función hash que el emisor, y si coincide con el hash del emisor la autenticidad del mensaje está asegurada (integridad).

- Una firma digital es imposible de falsificar si no se tiene la clave privada del firmante.
- La firma digital es un cifrado del mensaje que está firmando, pero utilizando la clave privada en lugar de la pública.
- Realmente, la firma digital es el resultado de cifrar con la clave privada el resumen de los datos a firmar, haciendo uso de funciones de hash.

Sirve para garantizar que el emisor es exactamente quien dice ser.

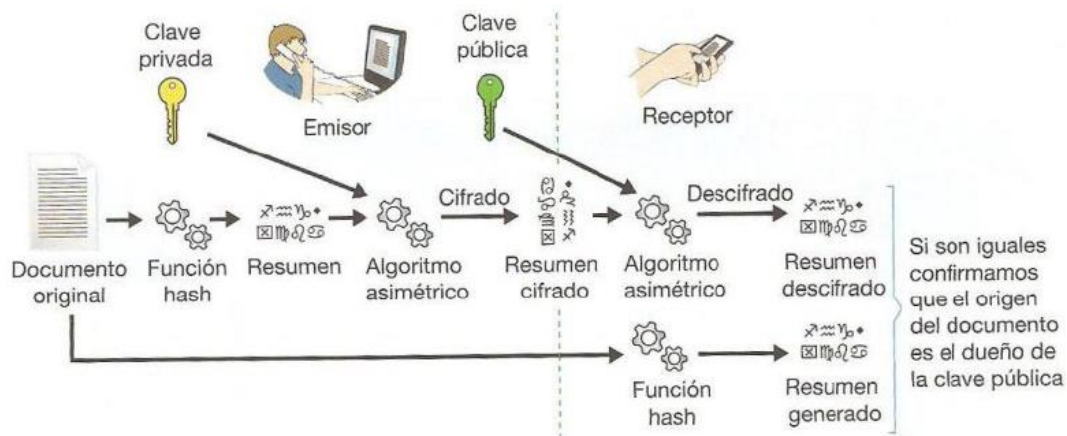
7-Firma digital y Certificados electrónicos

Firma digital:



Firma digital:

[Ejemplo 02]



8-Certificado electrónico o digital

La eficacia de la firma digital solamente está garantizada si:

- Se tiene la certeza de que la clave privada solo la conoce el usuario afectado.
- Que la publica la puede conocer todo el mundo y no puede haber confusión entre las claves públicas de los diferentes usuarios.

Para asegurar la singularidad de la clave privada > smartcards con PIN

Para asegurar la singularidad de la clave pública > certificado digital (Documento electrónico que asocia una clave pública con la identidad de su propietario).

Asociar una clave pública con la identidad del propietario:

Sirve para asegurar la procedencia de la clave pública en el proceso de la firma digital o para cifrar un mensaje. Hay certificados para usuarios, servidores web, emails, etc...

Suelen ser expedidos por autoridades certificadoras (pueden ser públicas o privadas).

8-Certificado electrónico o digital**[Continuación]****Utilidad del certificado digital:**

- Identificar al interlocutor.
- Cifrar datos digitales.
- Firmar digitalmente los datos (documentos, software, etc).
- Garantizar el no repudio (no es posible negar que la transacción se realizó).

Elementos indispensables:**Clave pública**

Del propietario del certificado.

Identidad del propietario

Información a certificar. Ejemplo: DNI, CIF, email, nombre del equipo, dns...

Firma digital de la autoridad certificadora

Reconocida por emisor y receptor. La autoridad firma el certificado con su clave privada > el documento certifica que la clave pública del certificado está relacionada con la identidad del propietario.

Periodo de validez

Cuando expira se tiene que solicitar de nuevo.

9- PKI (Public Key Infrastructure)**Infraestructura de clave pública:**

Una vez definido el certificado digital ¿Cómo confiar si es válido o esta falsificado?

- La validez del certificado es la confianza en que la clave publica contenida en el certificado pertenece al usuario indicado en el certificado.
- La manera de confiar en un usuario que no conocemos es en la confianza en terceras partes: dos usuarios pueden confiar directamente entre ellos, si ambos tienen relación con una tercera parte que puede dar fe de la fiabilidad de los dos > Autoridad de certificación (CA).

9- PKI (Public Key Infrastructure)**[Continuación]****Autoridad de certificación (CA)**

- La tercera parte confiable es fundamental en cualquier entorno de clave publica, para funcionar de agente en que todos los usuarios confien para la distribución de sus claves publicas y para que se encarguen de su publicación en algún repositorio al que todos los usuarios tengan acceso.
- La tercera parte confiable se conoce con el nombre de Autoridad de certificación (CA).
- La forma en que este avalara que el certificado es de fiar es poniendo su firma digital sobre el certificado.

Una PKI es el conjunto de elementos que se necesitan para crear un sistema de certificación.

Para comprobar que la clave pública corresponde a un emisor específico (no repudio) y garantizar la autenticidad de un mensaje cifrado.

Se compone de:

Autoridad de certificación	(CA [Certificate Authority]) > Emite certificados.
Autoridad de Registro	(RA[Registration Authority]) > Asegura que el solicitante del certificado es quien dice ser.
Autoridad de Validación	(VA [Validation Authority]) > Comprueba la validez de los certificados digitales emitidos.
Repositorios	Almacenes de certificados. Los principales son el repositorio de certificados activos y el repositorio de listas de revocación de certificados.
Servidores web	Publican los certificados.

10- Root certificate

¿Cómo podemos estar seguros de que la clave pública de la CA es auténtica? Porque se ha instalado en nuestro ordenador de modo seguro. Esto se suele denominar certificado de raíz (root certificate)

11- Protocolos de comunicación**Que utilizan algoritmos y tecnologías de clave simétrica:**

- DSS (Data Distribution Service)
- PGP (Pretty Good Privacy)
- GPG/GnuPG (GNU Privacy Guard)
- SSH (Secure SHell)
- SSL (Secure Sockets Layer)
- TLS (Transport Layer Security)

*SSL y TLS son equivalentes y por esto se les referencia con SSL/TLS (a partir del SSL se desarrollo TLS)

12-Protocolo SSH

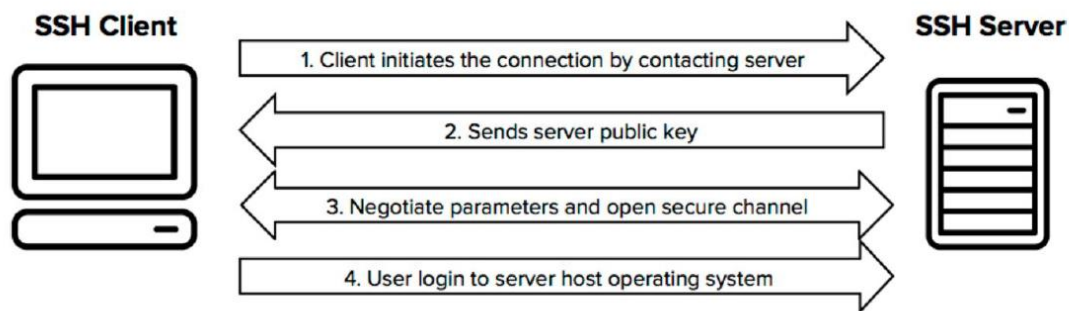
Permite cifrar la comunicación de extremo a extremo y conectar con sistemas en remoto con una conexión segura.

Crea túneles seguros y cifra la información que viaja por ellos > se cifra en la entrada y se descifra en la salida.

Evita problemas de suplantación de IP (IP spoofing), suplantación de DNS (DSN Spoofing) o interceptación de datos.

Herramienta muy útil para administradores de redes... Y hackers.

Buen sustituto de telnet para sesiones interactivas, sustituto del FTP para transferir archivos.



[0512222-04:5]

-Final evaluación 01-

1-Seguridad pasiva

[SAI]

Und
04

¿Qué es un SAI?

Un SAI (Acrónimo de sistema de alimentación ininterrumpida; en ingles UPS) es un aparato eléctrico que suministra energía eléctrica cuando la fuente primaria de electricidad falla.

Un SAI, a diferencia que un generador de emergencia, da energía eléctrica casi instantáneamente tras que se produce la caída de la fuente de alimentación primaria. Esto lo consigue mediante la energía que tiene almacenada en baterías, volantes de inercia, supercondensadores u otras alternativas.

Normalmente provee de tiempo suficiente para o bien realizar las tareas necesarias para poder apagar el sistema con seguridad, o para cambiar a un sistema de alimentación secundario.

Características relevantes de un SAI:

Potencia que puede suministrar	Determina el número de servidores que podemos conectar.
Tiempo de duración de las baterías	El número de baterías determina el tiempo que podrán suministrar corriente antes de extinguirse.
Tiempo de vida de las baterías	Es el fabricante del SAI quien determina cada cuantos años se tienen que cambiar las baterías.
Aviso al servidor	Actualmente, los SAI tienen una línea (USB o serie) que llega al ordenador. Se establece un dialogo que informa del estado de las baterías del SAI y de su duración. Cuando falta poco para agotar la carga de las baterías, el SAI informa al servidor y puede proceder a enviar mensajes a los usuarios, y hacer una parada correcta, ordenada y automática del ordenador.

A tener en cuenta:

- Importante conocer el consumo eléctrico de los equipos para poder escoger el SAI adecuadamente.
- Actualizar las contraseñas de acceso a los servidores remotos en caso de una parada.
- Tener configurado el usuario y la contraseña del servidor de correo que ha de enviar el aviso antes del fallo.
- Recordar enchufar al SAI también los equipos de red para poder enviar el correo (router, switch...)

AC Power Failure > Corte de corriente**AC Power Restored** > Recuperación del suministro

Según el tiempo entre uno y otro, ajustaremos la espera del SAI antes de lanzar la detención de los equipos.

1-Seguridad pasiva**[SAI] [Continuación]**

El SAI casi nunca entra en acción, pero cuando lo hace es importantísimo que todo funcione correctamente (y que lo hayamos probado antes):

- Baterías en buen estado.
- Contraseñas de acceso a servidores remotos actualizadas.
- Usuario + Contraseña del servidor de correo que tiene que enviar el aviso.
- Que estén bien conectados al SAI los equipos de red (Router, switch).

2 – Copias de seguridad**[Backup]**

Réplicas de datos que nos permiten recuperar la información original en caso de ser necesario: datos de usuarios, configuración de los equipos...

Parametros:

¿Qué Salvar?	Archivos, directorios, discos, particiones, equipos...
	Los sistemas complejos como bases de datos tienen sus propios mecanismos.
¿Dónde salvarlo?	Destino de la copia de seguridad:
	Local (Mismo equipo, disco externo por USB) > Amenazas físicas.
	Remota (En otro servidor, cloud) > Control de acceso.
¿Tipos?	Completa, diferencial, incremental.
¿Cuándo?	Programación automática.

“La nube (cloud) no existe, es el ordenador de otro”

Siempre tener una copia en local, en un servidor dedicado que puedas controlar tú y al que el resto de usuarios no tengan acceso.

+ copias externas.

2 – Copias de seguridad**[Regla 3-2-1]**

Regla 3-2-1 de copias de seguridad:

- Tener 3 copias de seguridad diferentes (original y 2 copias).
- Tener 2 soportes diferentes.
- Tener 1 copia fuera de la empresa.

Planificar los backups!

Concepto de granularidad = Cada cuanto tiempo se genera la copia de seguridad.

2 – Copias de seguridad**[Dispositivos de Backup]****Soportes físicos:**

- Otra partición del mismo disco duro.
- Otro disco de la misma máquina.
- Disco duro extraíble.
- Disco duro de otra máquina. Accediendo por FTP.
- Disco óptico (CD/DVD/BR).
- Cinta
 - Tienen mayor capacidad.
 - Son más fiables y reutilizables.
 - Por ejemplo: LTO (Linear Tape-Open).

2 – Copias de seguridad**[Tipos de Backup]****-Tipos de copias de seguridad-****Según los datos que se copian:**

Completa	Se copian todos los ficheros.
Incremental	Se copian todos los ficheros que han cambiado desde la última copia.
Diferencial	Se copian todos los ficheros que han cambiado desde la última copia completa.

Según la programación:

Manuales	Un usuario realiza las copias manualmente.
Automáticas	Se automatiza la frecuencia de las copias mediante un planificador (cron).

Según la ubicación:

Locales	Disco duro local, disco duro externo.
Remotas	En un servidor con servicio de ficheros en red.

Completa	Copia todos los archivos y directorios seleccionados.
Diferencial	Solo copia los archivos creados o modificados desde la última copia de seguridad completa realizada.
Incremental	Se copian los archivos que se han modificado desde la última copia de seguridad completa, diferencial o incremental. La diferencia entre esta y la diferencial es que esta ocupa menos espacio, pero para restaurar un archivo, necesitamos la copia de seguridad completa y todas las copias incrementales realizadas.

2 – Copias de seguridad**[Recomendaciones]**

Si el volumen de la copia de seguridad no es muy grande (4GB aprox.) Lo más práctico es hacer una copia completa.

Si el volumen de la copia de seguridad es muy elevado (50 GB) pero el volumen que se modifica no es muy grande (4GB aprox.), lo más práctico es realizar una primera copia completa y después copias diferenciales.

Si el volumen de la copia de seguridad es muy elevado (50GB) y el volumen de datos que se modifican también, lo mejor es hacer una copia completa y después incrementales.

Para garantizar la disponibilidad de todos los datos, en caso de desastre, es recomendable distribuir las copias de seguridad en diferentes ubicaciones o hacer un backup online a la nube.

Es recomendable cifrar las backups.

3 – Imagen del sistema**[Copia de seguridad de los programas: SO + aplicaciones]**

Es un volcado del contenido del disco duro.

- Contiene programas, datos del sistema operativo, etc.
- Solamente se hace después de instalarse o cuando hay un cambio importante.
- LiveCD: almacenamiento extraíble (CD/DVD/USB) que contiene un sistema operativo que puede ejecutarse sin tener que instalarse.
-

4 – Modelos de almacenamiento

Forma en que los discos que contienen datos se conectan a los servidores o a la red para ser servidos a los clientes de la red:

DAS (Direct Attached Storage)	Conectar los discos directamente al servidor o estación de trabajo.
NAS (Network Attached Storage)	Compartir en red los discos con los cuales los clientes se comunican por LAN. Se utilizan protocolos de red como NFS,FTP,CIFS o SMB.
SAN (Storage Area Network)	Mezcla de DAS y NAS, tecnología más cara. Los discos no están dentro de los servidores, y se utilizan dos redes locales: La de acceso a los medios de almacenamiento (SAN) y la LAN de los clientes.

4 – Modelos de almacenamiento**[Continuación]**

¿Cuándo emplear cada modelo?

DAS

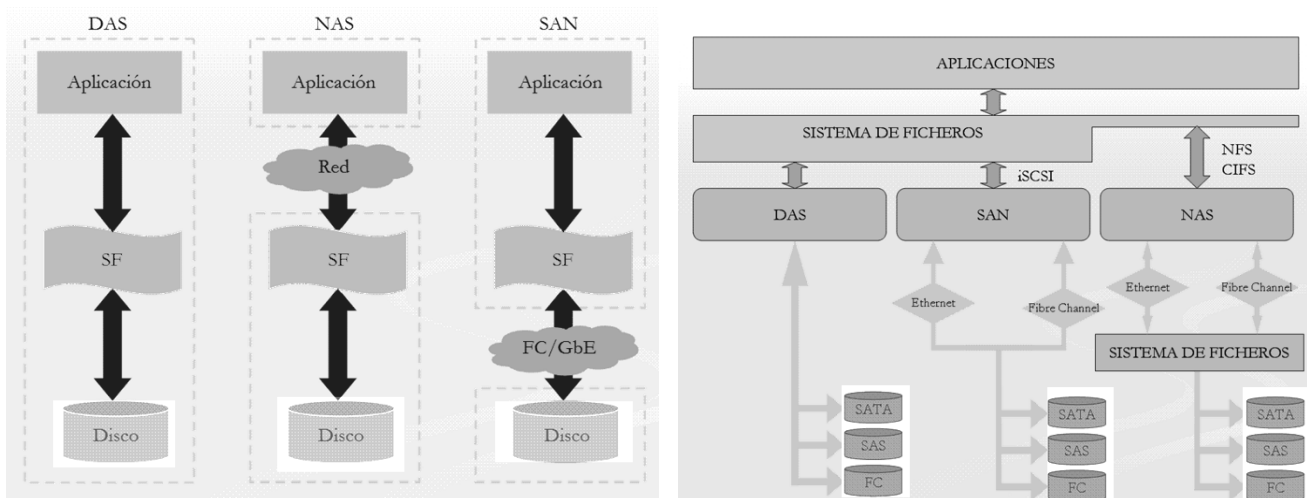
Cuando se necesita que el coste inicial sea bajo.

NAS

Cuando se quiera optimizar la facilidad de uso y se necesita compartir ficheros sobre redes ethernet.

SAN

Cuando se necesite un sistema de alto rendimiento, escalable y de alta disponibilidad.

**4 – Modelos de almacenamiento****[RAID]****RAID 0**Se unen dos o más discos, juntando su tamaño, aumenta la velocidad de lectura y escritura. **[2 o más discos]****RAID 1**Copia en espejo. El contenido de uno de los discos se copia en “espejo” en el otro. **[2 o más discos]****RAID 5**Se repite la información por igual, añadiendo paridad (control de errores) **[3 discos mínimo]****RAID 10**Dos ‘espejos’ RAID 1 unidos mediante RAID 0 **[mínimo 4 discos]****RAID 01**Dos pares de discos unidos cada par en modo RAID 0, y luego estas parejas de RAID 0 unidas entre sí en modo ‘espejo’ o RAID 1 **[mínimo 4 discos]**

4 – Modelos de almacenamiento**[RAID] [Continuación]**

Tipos de métodos de RAID:

RAID x Hardware	Fiable y recomendable, suele ser una controladora que se instala en la placa madre.
RAID x Software	No es fiable, no detecta errores o daños en el hardware.

5 – Balanceador de carga

Un balanceador de carga es un sistema que se emplea cuando se tiene que atender mucho tránsito en una aplicación/web o red. Consiste en crear un grupo de servidores / dispositivos de red, que se encargan de atender las solicitudes que recibe un servicio, como por ejemplo una página web, servidores de correo electrónico, un servicio de red, una conexión a internet, etc...

Los balanceadores de carga se agrupan en dos categorías:

Capa 4	Los balanceadores de carga de capa 4 actúan sobre los datos que se encuentran en los protocolos de la capa de red y transporte (IP,TCP,FTP,UDP).
Capa 7	Los balanceadores de carga de capa 7 distribuyen las solicitudes en función de los datos que se encuentran en los protocolos de la capa de aplicación como por ejemplo el HTTP.

Tipos de balanceadores:

Basados en hardware	Son dispositivos (denominados habitualmente appliances) que se encargan de gestionar el tránsito entre los diversos servidores que tienen que estar en funcionamiento.
Basados en software	Un balanceador de carga por software facilita la distribución eficiente del tránsito de la red. Esta aplicación recibe tránsito de diferentes fuentes y distribuye el tránsito entre servidores de datos. Además, la aplicación sirve como servidor intermediario inverso, recuperando recursos de los servidores y devolviéndolos a los clientes, pareciendo como si se hubieran originado desde un servidor intermediario.
Basados en la nube	Se trata de balanceadores más modernos y hacia dónde se dirige el mercado. El modelo de “pay per use” o PPE, ha hecho que sean uno de los sistemas más demandados, ya que tienen una fácil administración, alto rendimiento y unos costes mucho más reducidos que los anteriores.

6 – DRP (Disaster Recovery Plan)**Metodología para el diseño de un DRP:**

- 1- Inicio del proyecto Plan de Recuperación ante desastres.
- 2- Análisis de impacto sobre el negocio (BIA).
- 3- Análisis de riesgos.
- 4- Desarrollo de estrategias de recuperación para el DRP.
- 5- Roles y responsabilidades.
- 6- Pruebas del DRP.

[14-01-2023 21:32]**1-Seguridad activa**

La seguridad activa tiene que ser como una carrera de obstáculos. Ponerle difícil a los atacantes el poder acceder al sistema.

**Und
05**

2-Seguridad activa**[Física]**

Para evitar que la caja del equipo se pueda abrir; una cadena. Si se trata de un portátil, un candado “Kensington”.

3-Seguridad activa**[Pebkac]**

El mayor peligro de seguridad informática, es el que se encuentra entre el teclado y la silla.

Nunca confíes en los usuarios.

Principio de privilegios mínimos.

Todo lo que no está permitido, ha de estar prohibido.

4-Seguridad activa**[Seguridad en el sistema]****BIOS**

Poner contraseña y cambiar la contraseña del administrador.

Boot manager/GRUB

Poner contraseña.

Autenticación en sistema

Definir políticas de contraseñas.

Seguridad de ficheros

Definir permisos, sobre todo para gestionar carpetas comunitarias.

5-Seguridad activa**[Seguridad en la BIOS y gestores de arranque]****Acceso a la BIOS**

En la BIOS se configuran algunas de las características básicas de los equipos, **su acceso siempre tiene que estar protegido por una contraseña.**

Orden de arranque

Cambiar el orden de encendido en el BIOS para que solo pueda leer el HD, **evitando así que se pueda acceder con un LiveCD o Clonezilla.**

Boot manager

Especificar que SO queremos que inicie (Si tenemos más de uno) y **asignar contraseñas a los gestores de arranque.**

6-Seguridad activa**[Tipos de BIOS]****BIOS**

(Basic Input Output System) – 1975 Es un padrino dentro de la informática.

UEFI

(Unified Extensible Firmware Interface) – 2006 UEFI ha sustituido a BIOS.

Diferencias de la UEFI respecto a BIOS:

- Aspecto.
- Se puede conectar a internet para actualizarse.
- Se puede ejecutar en 64 bits.
- Mejora la seguridad mediante SECURE BOOT.
- Se puede cargar desde cualquier recurso no volátil, independientemente del SO.
-

7-Seguridad activa**[Reset de BIOS]**

Si olvidamos el password del BIOS podemos resetearla mediante dos métodos:

- Retirando unos segundos la pila que mantiene sus valores en memoria.
- Empleando un jumper de la placa base (si está cerrado cuando el ordenador se pone en marcha, se borran los valores del BIOS).
-

8-Seguridad activa**[Boot manager (GRUB)]**

Gestor de arranque que permite escoger con que sistema operativo queremos hacer el trabajo. Podemos establecer quien puede acceder a cada opción.

El boot manager grub de Linux nos permite poner usuario/password para entrar en las diferentes opciones modificando el fichero:

/boot/grub/grub.cfg

8-Seguridad activa**[Cifrado de particiones]**

Para evitar que se pueda acceder a nuestros datos:

- Hace que las particiones no sean legibles.
- No se pueden leer las particiones con un LiveCD.
- Bitlocker.
- UEFI.

9-Seguridad activa**[Seguridad lógica]**

La seguridad lógica consiste en la aplicación de barreras y procedimientos que controlan el acceso a los datos y solamente se permite acceder a las personas autorizadas para hacerlo.

Mecanismo de autenticación del sistema operativo:

- Usuario / contraseña (Poner un límite de intentos y bloquear si se pasa)
- Tarjetas.
- Biometría.

10- Seguridad activa**[Política de contraseñas]**

- Asegurar la fortaleza de las contraseñas.
- Asegurar que se guardan en un lugar seguro.
 - o Gestores de contraseñas. Ejemplo (keepass)
- Asegurar que nos comunicamos de forma segura.
 - o Criptografía: cifrar archivos, comunicación, mails...

11- Seguridad activa**[Reglas de creación de contraseñas]**

- Establecer un número máximo de intentos para acceder al sistema.
- Obligar a cambiar la contraseña cada X tiempo y no repetir las anteriores.
- Obligar a cambiar las contraseñas por defecto.
- No emplear palabras usuales o relacionadas con el usuario (fecha nacimiento, DNI...)
- No emplear palabras de diccionario (Con significado) ni secuencias (123, qwerty)
- Combinar mayúsculas, minúsculas, números y caracteres especiales (@! *?)
- Longitud de mínimo 8 caracteres (a más larga, más resistirá a un ataque de fuerza bruta)
- No emplear la misma contraseña en entornos diferentes.
- No apuntar las contraseñas en papel o en un archivo de ordenador ni enviarlas por SMS, WhatsApp... Emplear un gestor de contraseñas como keepass.info
- Crear cuentas de usuario, para poder gestionar contraseñas, permisos y privilegios.

12- Seguridad activa**[Trucos creación de contraseñas]**

- Escoger una frase y seleccionar las primeras letras o silabas
Emili Darder mola mucho este 2021 = EDmme2021
- Emplear números y símbolos como si fueran letras
3m1l1D@rd3r2021

13- Seguridad activa**[Monitorización del sistema]****Revisar el estado del sistema:**

- Revisar logs (Accesos y otros sucesos del sistema)
- Activar copia sync de los logs.
- Revisar CPU.

/var/log/auth.log (Registra los login del sistema en linux)

14- Seguridad activa**[Recomendaciones]****Recomendaciones de seguridad:**

- Mantenerse informado sobre las novedades de seguridad.
- Mantener el equipo actualizado, tanto el sistema operativo como cualquier aplicación que halla instalada. Sobre todo, las herramientas antimalware ya que sus bases de datos se actualizan en función del nuevo malware que se conoce diariamente.
- Hacer copias de seguridad con frecuencia, guárdalas en un lugar y soporte seguro para evitar pérdidas importantes de datos.
- Utiliza software legal que suele ofrecer mejor garantía y soporte.
- Analiza el sistema de ficheros con varias herramientas, ya que el hecho que una herramienta no encuentre malware no significa que no estemos infectados.
- No nos hemos de fiar de todas las herramientas antimalware gratuitas o las que te alertan sobre que tu sistema está infectado, ya que algunas de ellas pueden contener código malicioso, publicidad engañosa, no ofrecer la protección prometida e incluso dar como resultados falsos positivos.

Hacer periódicamente escaneo de puertos, test de velocidad y conexiones de red para analizar si las aplicaciones que las emplean son las autorizadas.

[14-01-2023 22:38]

Acceso a Redes**[Examen final]****01-Redes cableadas**

En una empresa los equipos están conectados en una

Red de área local (LAN).

Und**06****Protocolos seguros**

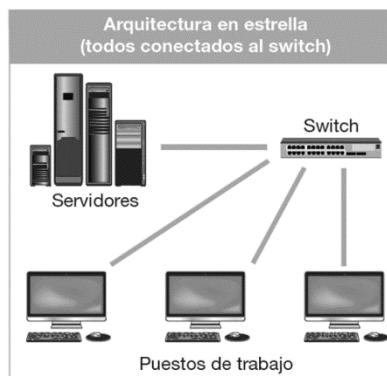
HTTPS – SSH

Protocolos inseguros

DHCP – DNS – HTTP

02-Arquitecturas de red**[No importante]**

No segura (antes)



Segura (ahora)

03- Protección ante vulnerabilidades**Proteger los switch físicamente**

Para evitar que alguien los pueda reconfigurar.

Proteger los switch lógicamente

(usuario/password): para evitar accesos a su configuración.

Hacer grupos de puertos (VLAN)

Para aislar diferentes grupos de maquinas y mejorar el rendimiento y la seguridad.

Controlar que equipos se pueden conectar y a que puertos.

04 - VLAN (Virtual LAN)

Los puertos pueden ser de los tipos:

Access

Solamente transportan el tráfico de una VLAN

Trunk

Pueden transportar el tráfico de varias VLAN

05 - VLAN etiquetada

Los puertos de tipo trunk añaden una etiqueta (tag) los paquetes de datos para saber a qué VLAN pertenecen.

VLAN (Virtual LAN)**[Continuación]****06 - Medidas de seguridad VLAN****Autenticación en el puerto**

El switch solamente permite conectar desde una dirección MAC concreta (el switch tiene una lista definida con las MAC de los equipos permitidos)

Autenticación con usuario/passw

Mediante un servidor RADIUS en el standard 802.1x.

1 – Habilitar autenticación 802.1x en el switch.

2- Establecer IP del servidor RADIUS.

3- Ubuntu: paquete FreeRadius.

4- En el cliente configurar tarjeta de red para habilitar la autenticación IEEE 802.1x

07 - Servidor RADIUS

RADIUS (Remote Authentication Dial-In User Server) : Protocolo de autenticación que emplea los puertos 1812 y 1813 del UDP para establecer las conexiones.

*Se emplea como sistema de seguridad en redes locales. Actualmente en desuso, aunque se siguen empleando. Este tipo de servidores estaban integrados en los propios switches, y requerían de un control de usuario/password para permitir la navegación.

08 - WLAN (Wireless LAN)**AP Access Point**

Los puntos de acceso, deciden como hacer llegar los paquetes a su destino; por el aire o por cable.

SSID

Identificador de una red inalámbrica servida por un AP.

09 - Protección ante vulnerabilidades WLAN

- Proteger los AP físicamente; algo más complicado que con un switch porque los AP tienen que estar cerca de los usuarios para que capten la señal.
- Proteger los AP lógicamente (usuario/password).
- Controlar que clientes se pueden conectar (Autenticación).
- Separar en dos grupos de usuarios, haciendo que el AP emita diferentes SSID con distintas autenticaciones.
- Encriptar la transmisión entre el ordenador y el AP.

10 - Tipos de autenticación WLAN

Abierta	Sin autenticación.
Compartida	Misma clave para cifrar que para autenticar.
Acceso seguro	Diferentes claves para cifrar y autenticar. La clave de cifrado se genera automáticamente.
Autenticación MAC	El AP mantiene una lista de MAC autorizados.

11- Cifrado WEB, WPA,WPA2

WEB	[Wireline Equivalent Privacy] (Inseguro)
WPA	[Wi-Fi Protected Access] algoritmos más seguros (TKIP, AES) y con una longitud de claves más largas. Rotación automática de claves. [WPA Personal] Emplea una clave previamente compartida (PSK Pre-Shared Key) y protocolo TKIP para encriptar. [WPA Enterprise] Emplea un servidor de autenticación RADIUS para generar claves y certificados para cada empleado.
WPA2	Más seguro, emplea AES, más rapidez de cifrado, pero necesita más potencia de procesamiento que WPA.
WPA3	Nuevo del 2018, mejora la seguridad de WPA2.

12 - VPN (Virtual Private Network)

Una VPN es una tecnología de red que permite la extensión de una red local de forma segura sobre una red pública como internet.

VPN de acceso remoto	Los usuarios se conectan con la empresa desde dos lugares remotos.
VPN punto a punto	Conecta ubicaciones remotas como oficinas con una sede central de la organización. Se establece un túnel VPN en el que se encapsula el protocolo de red dentro de otro.
VPN over LAN	Emplea la misma red LAN de la empresa, aislando zonas y servicios de la red interna. Permita también mejorar la seguridad wifi haciendo túneles IPSec o SSL.

13 - Protocolos VPN

PPTP	(Point to Point Tunneling Protocol) Desarrollado por Microsoft y disponible en todas las plataformas Windows. Es sencillo y fácil de implementar, pero ofrece menor seguridad que L2TP.
L2TP	(Layer Two Tunneling Protocol) Estándar abierto y disponible en la mayoría de las plataformas Windows, Linux, Mac, etc. Se implementa sobre IPSec y proporciona altos niveles de seguridad. Se pueden usar certificados de seguridad de clave pública para cifrar los datos y garantizar la identidad de los usuarios de la VPN.

Control de Redes**[Examen final]****01- Herramientas de control de redes**

- Monitorizar el tráfico
- Analizar el tráfico (sniffer)
- Sonda (probé)

Und**07**

Una sonda es un equipo de la red programado para comportarse como un cliente normal de cualquier servicio desplegado.

Sniffer de red

Herramienta de Linux sencilla para analizar paquetes y hacer un volcado de todo el tráfico que llega a una tarjeta de red.

Es necesario poner la tarjeta en modo promiscuo (Captura todo lo que pasa por la tarjeta)

Útil para protocolos no orientados a conexión (IP, UDP,DHCP,DNS,ICMP)

Emplea la librería 'pcap'.

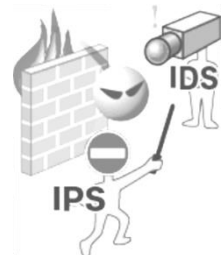
Análisis de tráfico

Se suelen emplear herramientas como 'Wireshark'. Sirve para capturar y analizar el tráfico de red.

02 – IDS / IPS**IDS****Sistema de detección de intrusos (IDS) DETECTA**

Detecta manipulaciones no deseadas en los sistemas o ataques no detectados por el firewall. Analiza el tráfico de la red y vigila las actividades de los usuarios de la red.

- Monitoriza los sucesos.
- Gestión de alertas basadas en reglas para avisar al usuario.

**IPS****Sistema de prevención de intrusos (IPS) ACTUA**

Monitoriza el tráfico de la red y/o las actividades de un sistema para identificar la actividad maliciosa y también intentar detener esta actividad. Permite establecer políticas de seguridad para proteger la red. (Es como una extensión del IDS)

03 – Tipos de IDS / IPS

HIDS/HIPS

(Host IDS/IPS) monitoriza cambios en el SO y aplicaciones.

Monitorización de una maquina (o varias, multihost) recogiendo información del SO (ficheros, logs, recursos...) verifican la integridad de ficheros, etc.

NIDS/NIPS

(Network IDS/IPS) monitoriza trafico de red y servicios.

Captura y analiza los paquetes de la red buscando patrones de ataque. (Puede ocasionar problemas de rendimiento).

DIDS/DIPS

(Distributed IDS/IPS) múltiples NIDS/NIPS que actúan como sensores centralizando la información de posibles ataques en una unidad central. Estructura habitual en redes VPN.

04-Firewall

Software especializado que se interpone entre las aplicaciones y el software de red para hacer un filtrado de paquetes.

- Puede ser por hardware o software.
- Puede filtrar trafico entrante o saliente.
- Más sencillo de configurar que un IPS.

Funciona con reglas de configuración de las cabeceras TCP/IP capas 3 (red), 4 (transporte) y 7 (aplicación) controlando:

- Direcciones IP.
- Puertos.
- Aplicaciones.

05- Firewall personal

Solamente protege el sistema donde se instala filtrando las conexiones locales con el exterior.

06 – Firewall domestico SOHO

El firewall doméstico o SOHO (Small Office Home Office) es un dispositivo de red que filtra las conexiones de una red doméstica (uno o más equipos) o pequeños negocios con el exterior.

- No se instala en los equipos individualmente, es externo.

07 – Firewall de nivel de aplicación

Más sofisticado y potente, mira datos del usuario. Se utiliza en protocolos web (HTTP). Es más lento.

08 – Firewall de red

Maquinas independientes que hacen trabajos de firewall, colocadas en puntos críticos de la red (ejemplo: máquina que también hace de router).

- En empresas pequeñas el cortafuego de red se suele poner en una máquina que también hace de router.
- En las empresas grandes hay maquinas diferentes para cada servicio, situadas en la DMZ.

09- Concepto de IPtables/Netfilter

Herramienta de comandos (Linux) para configurar las reglas de un cortafuego de filtrado de paquetes de red. Muy preciso, pero también difícil de utilizar.

10- ufw (Uncomplicated Firewall)

Permite configurar fácilmente las IPTables desde la línea de comandos. Para Ubuntu. (Consultar documentación practica adicional)

11 – Servidor proxy (Proxy server)

Software o dispositivo que hace una función en nombre de otro sistema o aplicación (cliente proxy) para quitar carga a los equipos de red.

Intercepta las peticiones de conexión que los clientes emiten hacia un servidor de destino.

Funciones habituales:

Controlar los accesos a servicios o recursos, proporcionar memoria cache para determinados servicios, registrar eventos de red, etc.

12-Proxy web (Proxy inverso)

Mascara que oculta nuestro equipo en la red. Enmascara la IP pero no cifra la conexión (No aumenta la seguridad como si hacen las VPN).

13 - Ettercap

Interceptor/sniffer para redes LAN con switch. Permite hacer ataques Man-in-the-middle (spoofing).

Empleado en las auditorias de red.

ARP Spoofing

Un atacante envía mensajes falsificados ARP a una LAN. El atacante vincula su dirección MAC con la IP de otro equipo, y así puede recibir los datos dirigidos a esa IP.

14-Protocolo IPsec

Es uno de los protocolos de seguridad en comunicaciones más importantes. Autentifica y cifra la información de cada paquete IP.

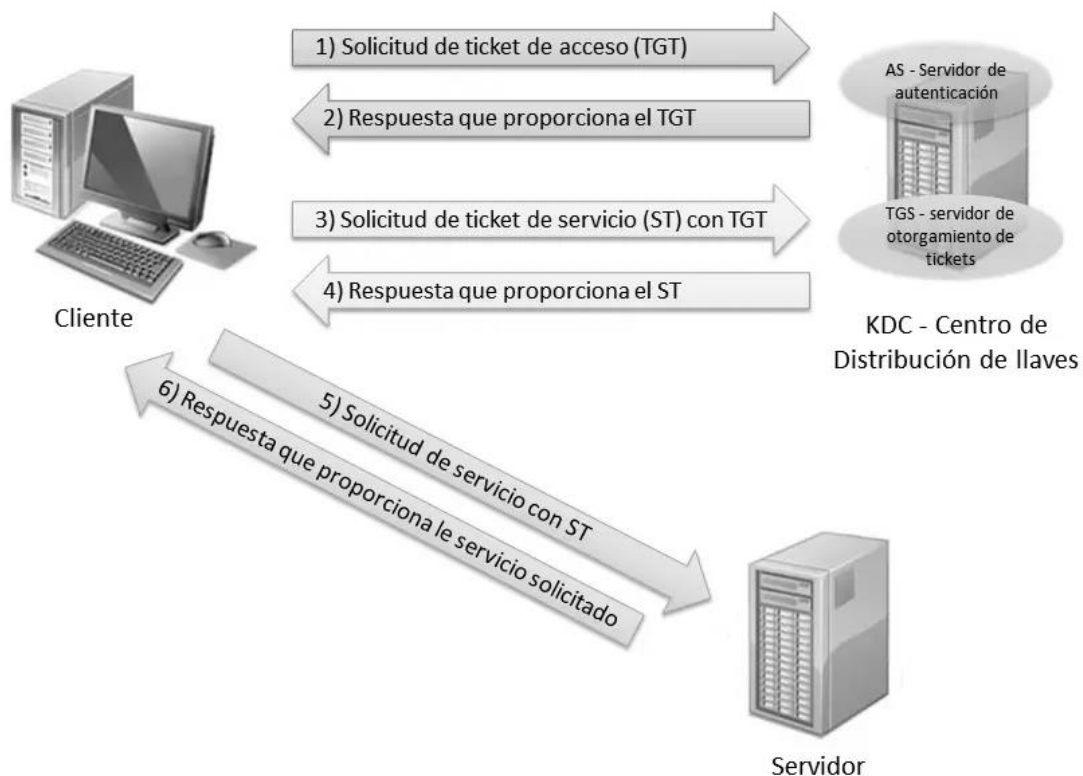
- Define el cifrado, autenticación y gestión de claves para transmisiones TCP/IP.
- Opera al nivel 3 del modelo OSI (red).
- Es nativo en IPv6, e insertado como una nueva capa de seguridad en IPv4.
- Base para la creación de VPN y conexiones remotas.

15-Kerberos

Es un protocolo de autenticación de redes informáticas, que permite a dos ordenadores de una red insegura demostrar su identidad mutuamente de modo seguro.

Ofrece autenticación mutua: tanto cliente como servidor verifican la identidad de uno y de otro.

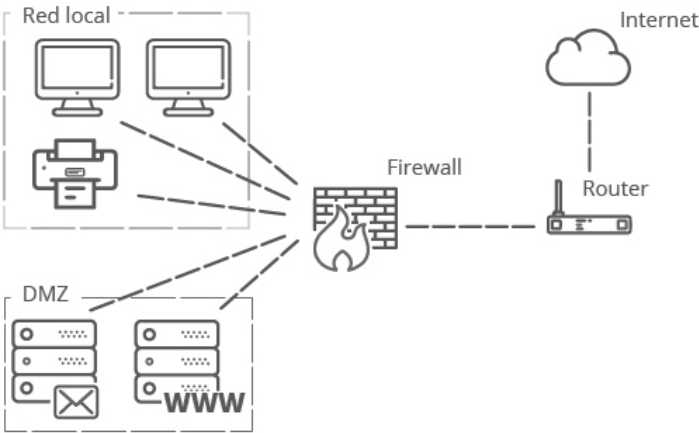
Kerberos se basa en criptografía de clave simétrica, y requiere de un tercero de confianza. Además, hay extensiones del protocolo para poder utilizar criptografía de clave asimétrica.



<https://www.incibe.es/protege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>

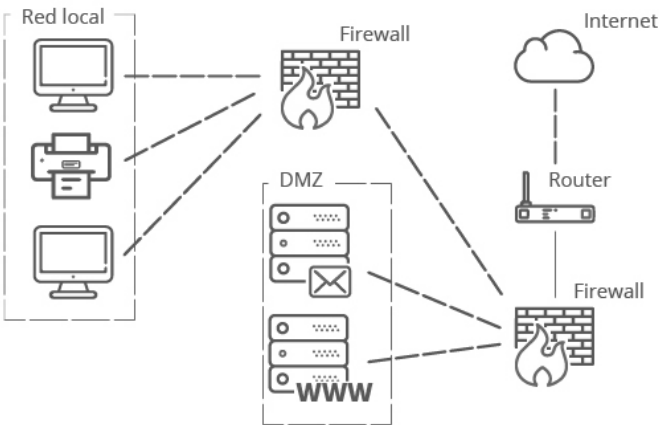
Anexo (DMZ):

[zona desmilitarizada]



Origen	Destino	Política
Internet	DMZ	Permitido
Internet	LAN	Denegado
DMZ	Internet	Permitido
DMZ	LAN	Denegado
LAN	DMZ	Permitido
LAN	Internet	Permitido

[Configuración ideal del DMZ]



[18-02-2023 02:46]